

第 7 章 网络安全



福州大学
FUZHOU UNIVERSITY

1

主要内容

计算机网络

7.1 网络安全概述

7.1.1 安全威胁

7.1.2 安全服务

7.2 机密性与密码学

7.2.1 对称密钥密码体制

7.2.2 公钥密码体制



福州大学
FUZHOU UNIVERSITY

2

主要内容

计算机网络

7.3 完整性与鉴别

7.3.1 报文摘要和报文鉴别码

7.3.2 数字签名

7.3.3 实体鉴别

7.4 密钥分发与公钥认证

7.4.1 对称密钥的分发

7.4.2 公钥的签发与认证



福州大学
FUZHOU UNIVERSITY

3

主要内容

计算机网络

7.5 访问控制

7.5.1 访问控制的基本概念

7.5.2 访问控制策略

7.6 网络各层的安全实例

7.6.1 物理层实例：信道加密机

7.6.2 数据链路层实例：802.11i

7.6.3 网络层实例：IPsec

7.6.4 运输层实例：SSL/TLS

7.6.5 应用层实例：PGP



福州大学
FUZHOU UNIVERSITY

4

主要内容

计算机网络

7.7 系统安全：防火墙与入侵检测

7.7.1 防火墙

7.7.2 入侵检测系统

7.8 网络攻击及其防范

7.8.1 网络扫描

7.8.2 网络监听

7.8.3 拒绝服务攻击



福州大学
FUZHOU UNIVERSITY

5

7.1 网络安全概述

计算机网络

■ 7.1.1 安全威胁

- 随着计算机网络的发展，网络中的安全问题也日趋严重
- 计算机网络上的通信面临以下的四种威胁：
 - (1) 截获——从网络上窃听他人的通信内容。
 - (2) 中断——有意中断他人在网络上的通信。
 - (3) 篡改——故意篡改网络上传送的报文。
 - (4) 伪造——伪造信息在网络上传送。
- 截获信息的攻击称为**被动攻击**，而更改信息和拒绝用户使用资源的攻击称为**主动攻击**。



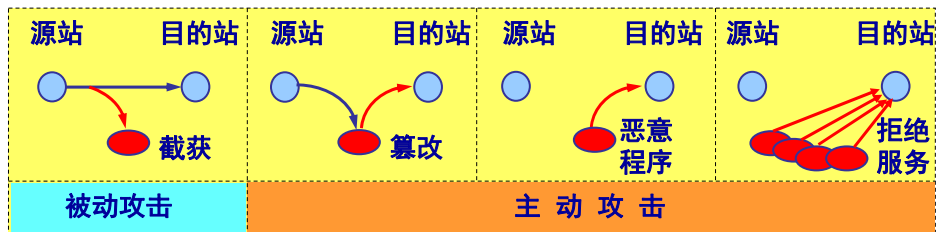
福州大学
FUZHOU UNIVERSITY

6

7.1.1 安全威胁

计算机网络

- 计算机网络上的通信面临以下两大类威胁：**被动攻击**和**主动攻击**。



福州大学
FUZHOU UNIVERSITY

7

7.1.1 安全威胁

计算机网络

■ 被动攻击

- 指攻击者从网络上窃听他人的通信内容。
- 通常把这类攻击成为**截获**。
- 在被动攻击中，攻击者只是观察和分析某一个协议数据单元 **PDU**，以便了解所交换的数据的某种性质。但不干扰信息流。
- 这种被动攻击又称为**流量分析 (traffic analysis)**。



福州大学
FUZHOU UNIVERSITY

8

7.1.1 安全威胁

计算机网络

■ 主动攻击主要有：

- (1) **篡改**——故意篡改网络上传送的报文。这种攻击方式有时也称为**更改报文流**。
- (2) **恶意程序**——种类繁多，对网络安全威胁较大的主要包括：计算机病毒、计算机蠕虫、特洛伊木马、逻辑炸弹、后门入侵、流氓软件等。
- (3) **拒绝服务**——指攻击者向互联网上的某个服务器不停地发送大量分组，使该服务器无法提供正常服务，甚至完全瘫痪。



福州大学
FUZHOU UNIVERSITY

9

7.1.1 安全威胁

计算机网络

■ 恶意程序(rogue program)

- (1) **计算机病毒**——会“传染”其他程序的程序，“传染”是通过修改其他程序来把自身或其变种复制进去完成的。
- (2) **计算机蠕虫**——通过网络的通信功能将自身从一个结点发送到另一个结点并启动运行的程序。
- (3) **特洛伊木马**——一种程序，它执行的功能超出所声称的功能。
- (4) **逻辑炸弹**——一种当运行环境满足某种特定条件时执行其他特殊功能的程序。



福州大学
FUZHOU UNIVERSITY

10

7.1.1 安全威胁

计算机网络

■ 分布式拒绝服务 DDoS

- 若从互联网上的成百上千的网站集中攻击一个网站，则称为**分布式拒绝服务 DDoS (Distributed Denial of Service)**。
- 有时也把这种攻击称为**网络带宽攻击**或**连通性攻击**



福州大学
FUZHOU UNIVERSITY

11

7.1.1 安全威胁

计算机网络

■ 计算机网络通信安全的目标

- 对于主动攻击，可以采取适当措施加以检测。
- 对于被动攻击，通常却是检测不出来的。
- 根据这些特点，可得出计算机网络通信安全的目标：
 - (1) 防止析出报文内容和流量分析。
 - (2) 防止恶意程序。
 - (3) 检测更改报文流和拒绝服务。
- 对付**被动攻击**可采用各种数据**加密**技术。

对付**主动攻击**则需将**加密**技术与适当的**鉴别**技术相结合。



福州大学
FUZHOU UNIVERSITY

12

7.1 网络安全概述

计算机网络

■ 7.1.2 安全服务

- **机密性(confidentiality)** 确保计算机系统上的信息或网络中传输的信息不会泄漏给非授权用户。这是计算机网络中**最基本的安全服务**，也是对付被动攻击必须具备的功能。为了使网络具有保密性，需要使用各种**密码技术**。



福州大学
FUZHOU UNIVERSITY

13

7.1 网络安全概述

计算机网络

■ 7.1.2 安全服务

- **报文完整性(message integrity)** 确保计算机系统上的信息或网络中传输的信息**不被非授权用户篡改或伪造**，后者要求对报文源进行鉴别。在应对主动攻击中是必不可少的。



福州大学
FUZHOU UNIVERSITY

14

7.1 网络安全概述

计算机网络

■ 7.1.2 安全服务

- **不可否认性(nonrepudiation)** 防止发送方或接收方否认传输或接收过某信息。在电子商务中这是一种非常重要安全服务。
- **实体鉴别(entity authentication)** 通信实体能够验证正在通信的对端实体的**真实身份**，确保不会与冒充者进行通信，在对付主动攻击中是非常重要的。



福州大学
FUZHOU UNIVERSITY

15

7.1 网络安全概述

计算机网络

■ 7.1.2 安全服务

- **访问控制(access control)** 系统具有限制和控制不同实体对信息源或其他系统资源进行访问的能力。系统必须在鉴别实体身份的基础上对实体的**访问权限**进行控制。
- **可用性(availability)** 确保授权用户能够正常访问系统信息或资源。拒绝服务攻击是可用性的最直接的威胁。



福州大学
FUZHOU UNIVERSITY

16

7.2 机密性与密码学

计算机网络

- 机密性应该是密码学最早的应用领域，但我们在后面几节将会看到密码学技术和鉴别、报文完整性以及不可否认性等是紧密相关的，可以说**密码学是计算机网络安全的基础**。



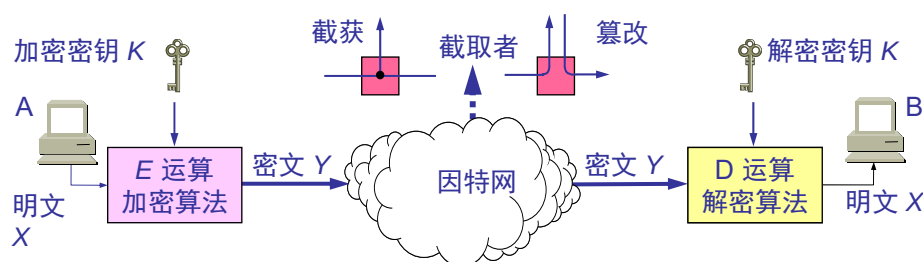
福州大学
FUZHOU UNIVERSITY

17

7.2 机密性与密码学

计算机网络

- 数据加密的一般模型



$$Y = E_{KE}(X)$$

$$D_{KD}(Y) = D_{KD}(E_{KE}(X)) = X$$



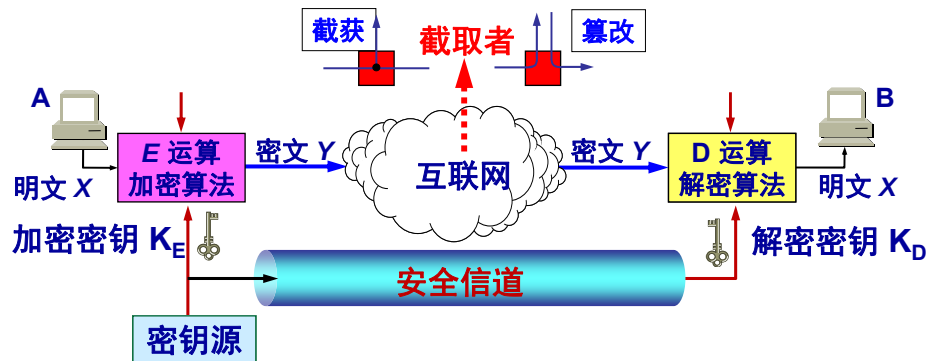
福州大学
FUZHOU UNIVERSITY

18

7.2 机密性与密码学

计算机网络

■ 数据加密的一般模型



用户 A 向 B 发送明文 X，通过加密算法 E 运算后，就得出密文 Y。

$$Y = E_{K_E}(X)$$

$$D_{K_D}(Y) = D_{K_D}(E_{K_E}(X)) = X$$



福州大学
FUZHOU UNIVERSITY

19

7.2 机密性与密码学

计算机网络

■ 密钥

- 加密和解密用的**密钥 K (key)** 是一串秘密的字符串（即比特串）。
- 明文通过**加密算法 E** 和**加密密钥 K** 变成密文：

$$Y = E_K(X) \quad (7-1)$$

- 接收端利用**解密算法 D** 运算和**解密密钥 K** 解出明文 X。解密算法是加密算法的逆运算。

$$D_K(Y) = D_K(E_K(X)) = X \quad (7-2)$$

- 加密密钥和解密密钥可以一样，也可以不一样。
- 密钥通常是由密钥中心提供。
- 当密钥需要向远地传送时，一定要通过另一个安全信道。



福州大学
FUZHOU UNIVERSITY

20

7.2 机密性与密码学

计算机网络

■ 一些重要概念

- 密码编码学 (cryptography) 是密码体制的设计学。
- 密码分析学 (cryptanalysis) 则是在未知密钥的情况下从密文推演出明文或密钥的技术。
- 密码编码学与密码分析学合起来即为密码学 (cryptology)。



福州大学
FUZHOU UNIVERSITY

21

7.2 机密性与密码学

计算机网络

■ 一些重要概念

- 如果不论截取者获得了多少密文，但在密文中都没有足够的信息来唯一地确定出对应的明文，则这一密码体制称为**无条件安全的**，或称为**理论上是不可破的**。
- 如果密码体制中的密码不能被可使用的计算资源破译，则这一密码体制称为在**计算上是安全的**。



福州大学
FUZHOU UNIVERSITY

22

7.2 机密性与密码学

计算机网络

- 7.2.1 对称密钥密码体制
- 7.2.2 公钥密码体制



福州大学
FUZHOU UNIVERSITY

23

7.2 机密性与密码学

计算机网络

- 7.2.1 对称密钥密码体制
 - 所谓**对称密钥密码体制**是一种**加密密钥**与**解密密钥相同**的密码体制。
 - 在这种加密系统中**两个参与者共享同一个秘密密钥**，如果用一个特定的密钥加密一条消息，也必须要使用相同的密钥来解密该消息。
 - 该系统又称为**对称密钥系统**。

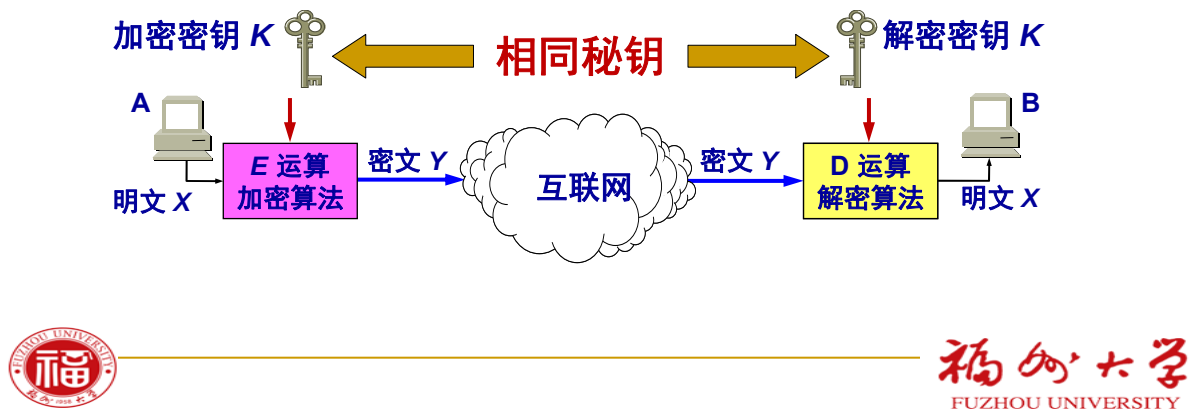


福州大学
FUZHOU UNIVERSITY

24

7.2.1 对称密钥密码体制

计算机网络



福州大学
FUZHOU UNIVERSITY

25

7.2.1 对称密钥密码体制

计算机网络

■ 数据加密标准 DES

- 数据加密标准DES (Data Encryption Standard)是对称密钥密码的典型代表，由IBM公司研制，于1977年被美国定为联邦信息标准后，在国际上引起了极大的重视。ISO曾把DES作为数据加密标准。



福州大学
FUZHOU UNIVERSITY

26

7.2.1 对称密钥密码体制

计算机网络

■ 数据加密标准 DES

- 数据加密标准 DES 属于对称密钥密码体制，是一种分组密码。
- 在加密前，先对整个明文进行分组。每一个组长为 64 位。
- 然后对每一个 64 位 二进制数据进行加密处理，产生一组 64 位密文数据。
- 最后将各组密文串接起来，即得出整个的密文。
- 使用的密钥为 64 位（实际密钥长度为 56 位，有 8 位用于奇偶校验）。



福州大学
FUZHOU UNIVERSITY

27

7.2.1 对称密钥密码体制

计算机网络

■ DES 的保密性

- DES 的保密性仅取决于对密钥的保密，而算法是公开的。尽管人们在破译 DES 方面取得了许多进展，但至今仍未能找到比穷举搜索密钥更有效的方法。
- DES 是世界上第一个公认的实用密码算法标准，它对密码学的发展做出了重大贡献。
- 目前较为严重的问题是 DES 的密钥的长度。
- 现在已经设计出来搜索 DES 密钥的专用芯片。56 位 DES 已不再认为是安全的了。



福州大学
FUZHOU UNIVERSITY

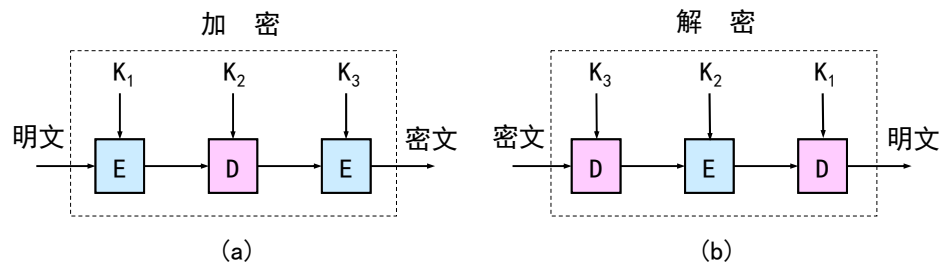
28

7.2.1 对称密钥密码体制

计算机网络

■ 三重DES

- 为解决DES密钥太短的问题，人们提出了三重DES



福州大学
FUZHOU UNIVERSITY

29

三重 DES

计算机网络

- 使用两个 56 位的密钥。
- 把一个 64 位明文用一个密钥加密，再用另一个密钥解密，然后再使用第一个密钥加密，即

$$Y = DES_{K_1}(DES_{K_2}^{-1}(DES_{K_1}(X)))$$



福州大学
FUZHOU UNIVERSITY

30

7.2 机密性与密码学

计算机网络

■ 7.2.2 公钥密码体制

- 公钥密码体制使用不同的加密密钥与解密密钥，是一种“由已知加密密钥推导出解密密钥在计算上是不可行的”密码体制。
- 公钥密码体制的产生主要是因为两个方面的原因，
 - 一是由于常规密钥密码体制的密钥分配问题，
 - 另一是由于对数字签名的需求。
- 现有最著名的公钥密码体制是RSA体制，它基于数论中大数分解问题的体制，由美国三位科学家 Rivest, Shamir 和 Adleman 于 1976 年提出并在 1978 年正式发表的。



福州大学
FUZHOU UNIVERSITY

31

7.2.2 公钥密码体制

计算机网络

■ 加密密钥与解密密钥

- 在公钥密码体制中，加密密钥(即公钥) PK 是公开信息，而解密密钥(即私钥或密钥) SK 是需要保密的。
- 加密算法 E 和解密算法 D 也都是公开的。
- 虽然密钥 SK 是由公钥 PK 决定的，但却不能根据 PK 计算出 SK。



福州大学
FUZHOU UNIVERSITY

32

7.2.2 公钥密码体制

计算机网络

■ 应当注意

- 任何加密方法的安全性取决于密钥的长度，以及攻破密文所需的计算量。
在这方面，公钥密码体制并不具有比传统加密体制更加优越之处。
- 公钥密码体制有许多很好的特性，但公钥密码算法比对称密码算法要慢好几个数量级。因此，对称密码被用于绝大部分加密，而公钥密码则通常用于会话密钥的建立。
- 公钥还需要**密钥分配协议**，具体的分配过程并不比采用传统加密方法时更简单。



福州大学
FUZHOU UNIVERSITY

33

7.2.2 公钥密码体制

计算机网络

■ 公钥算法的特点

- 密钥对产生器产生出接收者 **B** 的**一对密钥**：加密密钥 PK_B 和解密密钥 SK_B 。
 - **加密密钥 PK_B** 就是接收者 **B** 的**公钥**，它向公众公开。
 - **解密密钥 SK_B** 就是接收者 **B** 的**私钥**，对其他人都保密。
- 发送者 **A** 用 **B** 的**公钥 PK_B** 对明文 **X** **加密**（**E** 运算）后，在接收者 **B** 用自己的**私钥 SK_B** **解密**（**D** 运算），即可恢复出明文：

$$D_{SK_B}(Y) = D_{SK_B}(E_{PK_B}(X)) = X \quad (7-4)$$



福州大学
FUZHOU UNIVERSITY

34

7.2.2 公钥密码体制

计算机网络

■ 公钥算法的特点

- 加密密钥是公开的，但不能用它来解密，即：

$$D_{PK_B}(E_{PK_B}(X)) \neq X \quad (7-5)$$

- 加密和解密运算可以对调，即加密和解密是互逆的：

$$E_{PK_B}(D_{SK_B}(X)) = D_{SK_B}(E_{PK_B}(X)) = X \quad (7-6)$$



福州大学
FUZHOU UNIVERSITY

35

7.2.2 公钥密码体制

计算机网络

■ 公钥算法的特点（续）

- 在计算机上可容易地产生成对的 PK_B 和 SK_B 。
- 从已知的 PK_B 实际上不可能推导出 SK_B ，即从 PK_B 到 SK_B 是“计算上不可能的”。
- 加密和解密算法都是公开的。

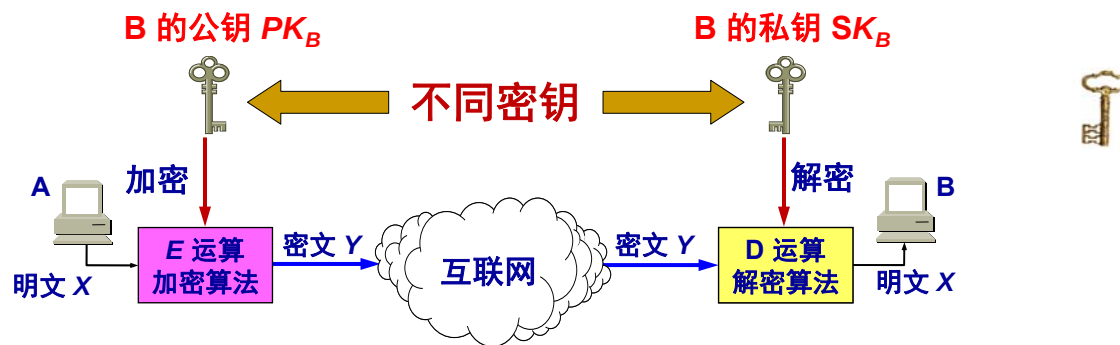


福州大学
FUZHOU UNIVERSITY

36

7.2.2 公钥密码体制

计算机网络



福州大学
FUZHOU UNIVERSITY

37

公开密钥与对称密钥的区别

计算机网络

- 在使用对称密钥时，由于双方使用同样的密钥，因此在通信信道上可以进行**一对一的双向保密通信**，每一方既可用此密钥加密明文，并发送给对方，也可接收密文，用同一密钥对密文解密。这种保密通信仅限于持有此密钥的双方（如再有第三方就不保密了）。
- 在使用公开密钥时，在通信信道上可以是**多对一的单向保密通信**。



福州大学
FUZHOU UNIVERSITY

38

7.2.2 公钥密码体制

计算机网络

- 如果某一信息用**公开密钥加密**，则必须用**私有密钥解密**，这就是实现**保密**的方法
- 如果某一信息用**私有密钥加密**，那么，它必须用**公开密钥解密**。这就是实现**数字签名**的方法



福州大学
FUZHOU UNIVERSITY

39

7.3 完整性与鉴别

计算机网络

7.3.1 报文鉴别

- 鉴别 (authentication) 是网络安全中一个很重要的问题。
- 鉴别包括：

实体鉴别

- 鉴别发信者，防止冒充者。
- 实体：发信的人或进程。
- 也常称为**端点鉴别**。

鉴别报文的完整性

- 报文未被他人篡改过。

报文鉴别通常包含：鉴别报文的发送者，鉴别报文的完整性。



福州大学
FUZHOU UNIVERSITY

40

7.3 完整性与鉴别

计算机网络

■ 7.3.1 报文鉴别

鉴别与加密不同

- 加密可以实现鉴别。
- 但许多报文不需要加密，但需要鉴别。

鉴别与授权不同

- 授权 (authorization) 涉及的问题是：所进行的过程是否被允许（如是否可以对某文件进行读或写）。



福州大学
FUZHOU UNIVERSITY

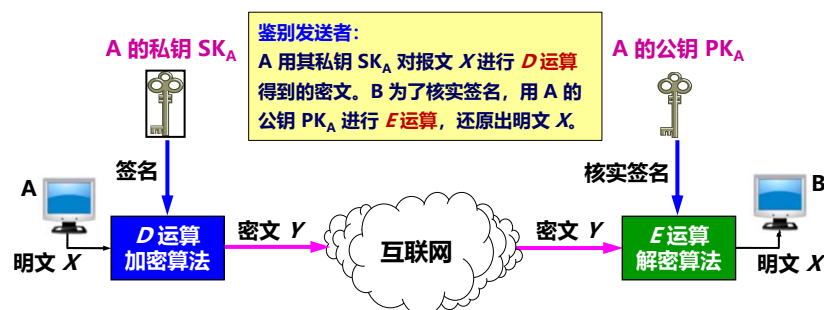
41

7.3 完整性与鉴别

计算机网络

■ 7.3.1 报文摘要和报文鉴别码

□ 1. 用数字签名进行鉴别（原理）



福州大学
FUZHOU UNIVERSITY

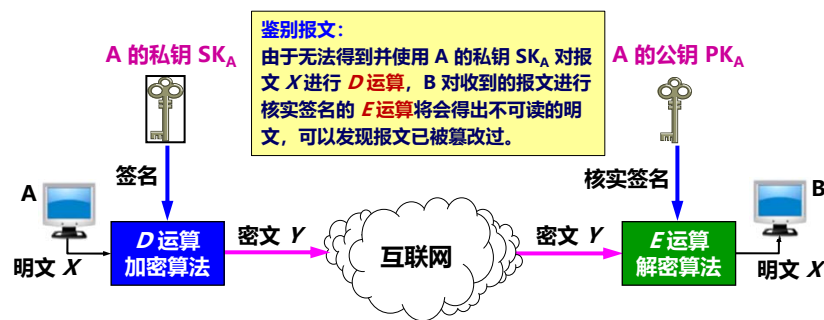
42

7.3 完整性与鉴别

计算机网络

■ 7.3.1 报文摘要和报文鉴别码

□ 1. 用数字签名进行鉴别（原理）



福州大学
FUZHOU UNIVERSITY

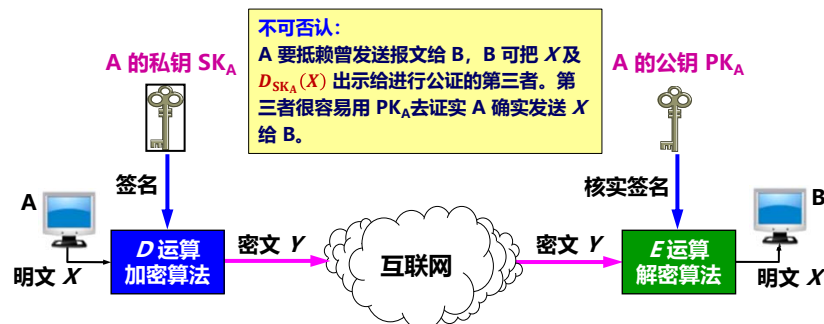
43

7.3 完整性与鉴别

计算机网络

■ 7.3.1 报文摘要和报文鉴别码

□ 1. 用数字签名进行鉴别（原理）



福州大学
FUZHOU UNIVERSITY

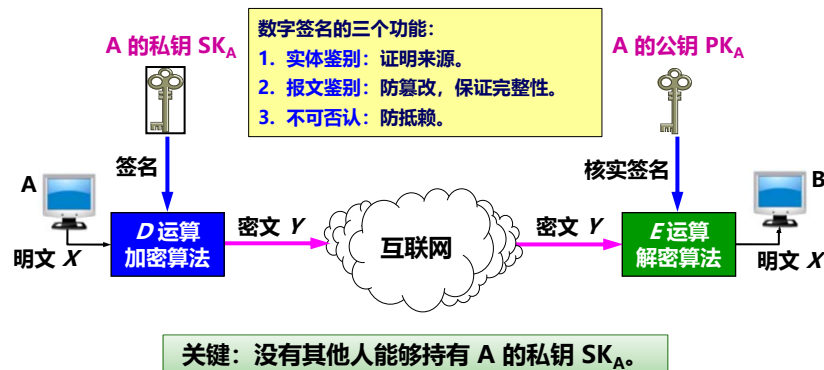
44

7.3 完整性与鉴别

计算机网络

■ 7.3.1 报文摘要和报文鉴别码

□ 1. 用数字签名进行鉴别（原理）



福州大学
FUZHOU UNIVERSITY

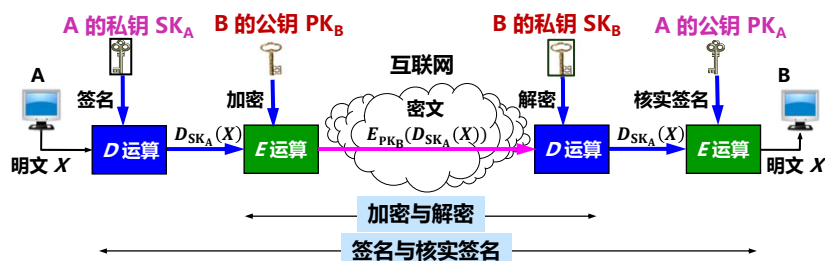
45

7.3 完整性与鉴别

计算机网络

■ 7.3.1 报文摘要和报文鉴别码

□ 可保证机密性的数字签名



- 先后进行两次 D 运算和两次 E 运算，运算量太大，花费非常多的 CPU 时间。目前普遍使用开销小得多的对称密钥加密。
- 要实现数字签名必须使用公钥密码，但一定要设法减小公钥密码算法的开销。



福州大学
FUZHOU UNIVERSITY

46

7.3 完整性与鉴别

计算机网络

■ 2. 密码散列函数

- 报文摘要和差错检验码都是多对一(**many-to-one**)的散列函数 (**hash function**, 又称为杂凑函数, 哈希函数) 的例子。但要抵御攻击者的恶意篡改, 报文摘要算法必须满足以下两个条件:
 - 任给一个报文摘要值 x , 若想找到一个报文 y 使得 $H(y) = x$, 则在计算上是不可行的。
 - 若想找到任意两个报文 x 和 y , 使得 $H(x) = H(y)$, 则在计算上是不可行的。
- 满足以上条件的散列函数称为**密码散列函数**



福州大学
FUZHOU UNIVERSITY

47

7.3 完整性与鉴别

计算机网络

■ 2. 密码散列函数

- 密码散列函数 $H(X)$ 应具有以下四个特点:
 1. 结果的长度应较短和固定。
 2. 应具有很好的抗碰撞性, 避免不同的输入产生相同的输出。
 3. 应是单向函数(**one-way function**), 不能逆向变换。
 4. 其他特性: 输出的每一个比特都与输入的每一个比特有关; 仅改动输入的一个比特, 输出也会相差极大; 包括许多非线性运算等。



福州大学
FUZHOU UNIVERSITY

48

7.3 完整性与鉴别

计算机网络

■ 2. 密码散列函数

- ❑ 差错检验码通常并不满足以上条件。
- ❑ 例如，很容易找到两个不同的字符串：“IOU100.99BOB”和“IOU900.19BOB”的校验和是完全一样的。
- ❑ 虽然差错检验码可以检测出报文的随机改变，但却无法抵御攻击者的恶意篡改，因为攻击者可以很容易地找到差错检验码与原文相同的其他报文，从而达到攻击目的。



福州大学
FUZHOU UNIVERSITY

49

7.3 完整性与鉴别

计算机网络

■ 2. 密码散列函数



散列 $H(X)$ 可用来保护明文X的完整性，防篡改和伪造。



福州大学
FUZHOU UNIVERSITY

50

7.3 完整性与鉴别

计算机网络

■ 广泛应用的报文摘要算法

- 目前广泛应用的报文摘要算法有**MD5** [RFC 1321]和安全散列算法1(Secure Hash Algorithm, **SHA-1**)。
- **MD5**输出128位的摘要，**SHA-1**输出160位的摘要。
- **SHA-1**比**MD5**更安全些，但计算起来比**MD5**要慢。



福州大学
FUZHOU UNIVERSITY

51

7.3 完整性与鉴别

计算机网络

■ MD5 算法

- **MD5**是**报文摘要 MD** (Message Digest) 的第5个版本。报文摘要算法**MD5**公布于**RFC 1321** (1991年)，并获得了非常广泛的应用。
- **MD5** 的设计者 **Rivest**曾提出一个猜想，即根据给定的 **MD5** 报文摘要代码，要找出一个与原来报文有相同报文摘要的另一报文，其难度在计算上几乎是不可能的。
- **基本思想：**
 - 用足够复杂的方法将报文的数据位充分“弄乱”，报文摘要代码中的每一位都与原来报文中的每一位有关。



福州大学
FUZHOU UNIVERSITY

52

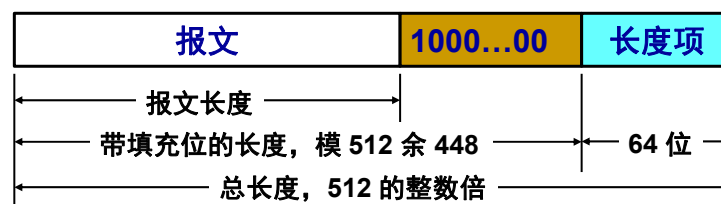
7.3 完整性与鉴别

计算机网络

■ MD5 算法

□ 计算步骤:

- **1, 附加:** 把任意长的报文按模 2^{64} 计算其余数 (64位), 追加在报文的后面 (长度项)。
- **2, 填充:** 在报文和长度项之间填充 1~512 位, 使得填充后的总长度是 512 的整数倍。填充的首位是 1, 后面都是 0。



福州大学
FUZHOU UNIVERSITY

53

7.3 完整性与鉴别

计算机网络

■ MD5 算法

□ 计算步骤 (续):

- **3, 分组:** 把追加和填充后的报文分割为一个个 512 位的数据块, 每个 512 位的报文数据再分成 4 个 128 位的数据块
- **4, 计算:** 将 4 个 128 位的数据块依次送到不同的散列函数进行 4 轮计算。每一轮又都按 32 位的小数据块进行复杂的运算。一直到最后计算出 MD5 报文摘要代码 (128 位)。



福州大学
FUZHOU UNIVERSITY

54

7.3 完整性与鉴别

计算机网络

■ 安全散列算法（SHA-1）

- 安全散列算法 **SHA (Secure Hash Algorithm)**是由美国标准与技术协会 **NIST** 提出一个散列算法系列。
- **SHA** 比 **MD5** 更安全，但计算起来却比 **MD5** 要慢些。
- 已制定 **SHA-1**、**SHA-2**、**SHA-3** 等版本。



福州大学
FUZHOU UNIVERSITY

55

7.3 完整性与鉴别

计算机网络

■ 安全散列算法（SHA-1）

- 基本思想：
 - 要求输入码长小于 2^{64} 位，输出码长为 160 位。
 - 将明文分成若干 512 位的定长块，每一块与当前的报文摘要值结合，产生报文摘要的下一个中间结果，直到处理完毕
 - 共扫描 5 遍，效率略低于 MD5，抗穷举性更高。



福州大学
FUZHOU UNIVERSITY

56

7.3 完整性与鉴别

机网络

■ 王小云院士

- 山东大学和清华大学教授
- 中国科学院院士
- 2004年破解MD5算法



- 在2004年，中国学者王小云发表了轰动世界的密码学论文，证明可以用系统的方法找出一对报文，这对报文具有相同的 MD5 报文，而这仅需 15 分钟，或不到 1 小时。MD5 的安全性就产生了动摇。随后，又有许多学者开发了对 MD5 实际的攻击。MD5 最终被安全散列算法 SHA 标准所取代。

□ 2005年破译SHA-1算法

- SHA-1 后来也被证明其实际安全性并未达到设计要求，并且也曾被王小云教授的研究团队攻破。谷歌也宣布了攻破 SHA-1 的消息。许多组织都已纷纷宣布停用 SHA-1。



福州大学
FUZHOU UNIVERSITY

57

7.3 完整性与鉴别

计算机网络

■ 安全散列算法 SHA-1

- SHA-1 已被 SHA-2、SHA-3 所替代。
- SHA-2 的多种变型：
 - SHA-224, SHA-256, SHA-384, SHA-512。
- SHA-3 的多种变型：
 - SHA3-224, SHA3-256, SHA3-384, SHA3-512。
- SHA-3 采用了与 SHA-2 完全不同的散列函数。

目前，密码学家尚无法把一个任意已知的报文 X ，篡改成具有同样 MD5 或 SHA-1 散列值的另一报文 Y 。



福州大学
FUZHOU UNIVERSITY

58

7.3 完整性与鉴别

计算机网络

■ 3. 用报文鉴别码实现报文鉴别

- MD5 实现的报文鉴别可以防篡改，但**不能防伪造**，因而不能真正实现报文鉴别。
- 例如：
 - 入侵者创建了一个伪造的报文 M ，然后计算出其散列 $H(M)$ ，并把拼接有散列的扩展报文冒充 A 发送给 B 。
 - B 收到扩展的报文 $(M, H(M))$ 后，通过散列函数的运算，计算出收到的报文 M_R 的散列 $H(M_R)$ 。
 - 若 $H(M) = H(M_R)$ ，则 B 就会误认为所收到的伪造报文就是 A 发送的。



福州大学
FUZHOU UNIVERSITY

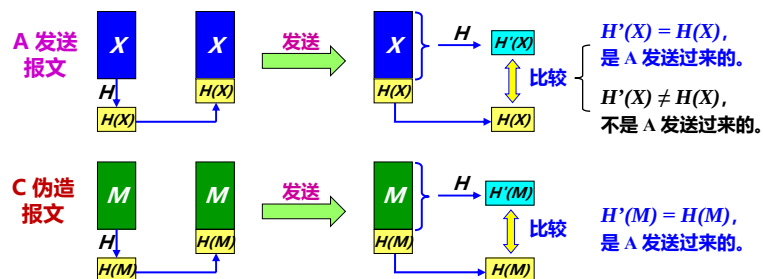
59

7.3 完整性与鉴别

计算机网络

■ 3. 用报文鉴别码实现报文鉴别

- MD5 实现的报文鉴别可以防篡改，但**不能防伪造**，因而不能真正实现报文鉴别。



福州大学
FUZHOU UNIVERSITY

60

7.3 完整性与鉴别

计算机网络

■ 解决办法：报文鉴别码 MAC

把**双方共享的密钥 K** 与**报文 X** 进行**拼接**，然后进行散列运算。
散列运算得出的结果为固定长度的 $H(X + K)$ ，称为**报文鉴别码 MAC** (Message Authentication Code)。



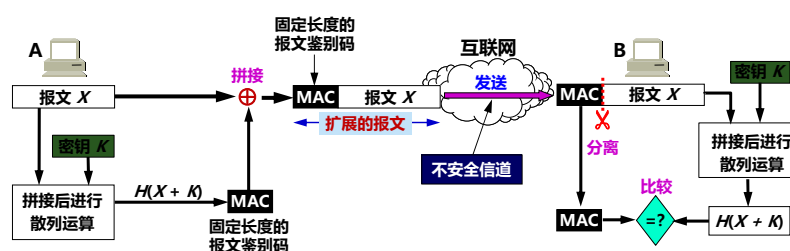
福州大学
FUZHOU UNIVERSITY

61

7.3 完整性与鉴别

计算机网络

■ 用报文鉴别码 MAC 鉴别报文



- 只要入侵者不掌握密钥 K ，就无法伪造 A 发送的报文（因为无法伪造 A 的 MAC）。
- 鉴别过程并没有执行加密算法，消耗的计算资源少。

这样的报文鉴别码称为**数字签名或数字指纹**。



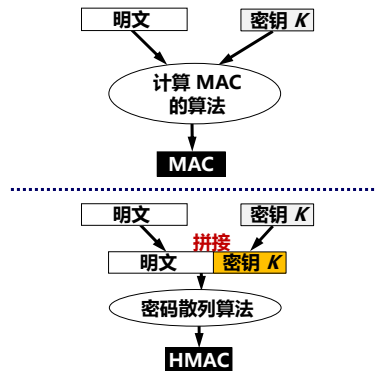
福州大学
FUZHOU UNIVERSITY

62

7.3 完整性与鉴别

计算机网络

■ HMAC 与 MAC 不同



MAC

- 把密钥 K 作为计算 MAC 的参数。
- 可以使用多种计算 MAC 的算法。

HMAC (Hashed MAC)

- 把密钥 K 拼接在明文后面。
- 使用密码散列算法对其进行运算。
- 得出的散列值就是 HMAC



福州大学
FUZHOU UNIVERSITY

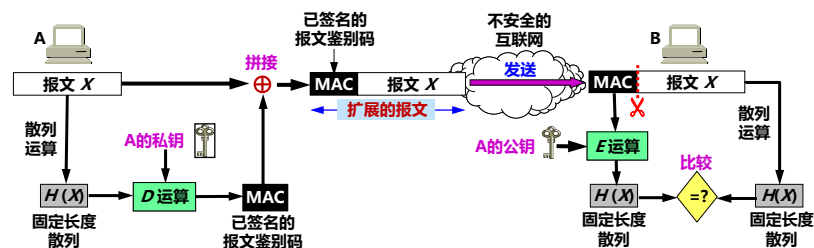
63

7.3 完整性与鉴别

计算机网络

■ 使用已签名的报文鉴别码 MAC 对报文鉴别

- **问题：**如何分发共享密钥 K ? **解决：**采用公钥系统。



- 没有对报文进行加密，而是对很短的散列 $H(X)$ 进行 D 运算。
- 入侵者没有 A 的私钥，因此不可能伪造出 A 发出的报文。

- 所得到的扩展报文：不可伪造，不可否认。
- 可简称为：“ A 用自己的私钥进行签名， B 用 A 的公钥进行鉴别”。



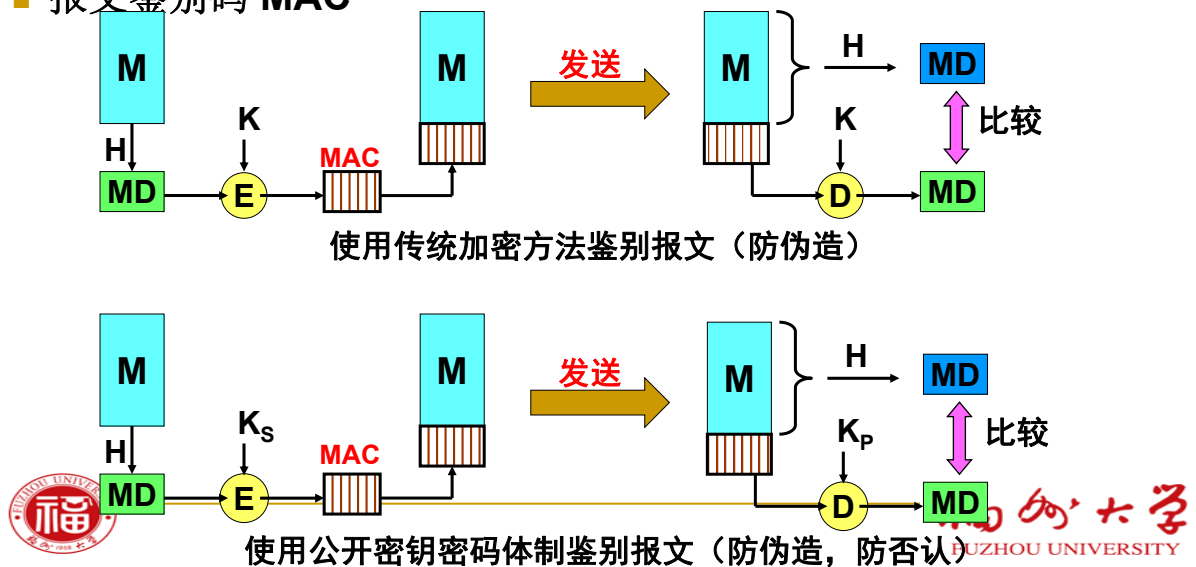
福州大学
FUZHOU UNIVERSITY

64

7.3 完整性与鉴别

计算机网络

■ 报文鉴别码 MAC



65

7.3 完整性与鉴别

计算机网络

■ 7.3.2 实体鉴别

- 实体鉴别与报文鉴别不同。
- **报文鉴别：**对每一个收到的报文都要鉴别报文的发送者。
- **实体鉴别：**在系统接入的全部持续时间内，对和自己通信的对方实体只需验证一次。



福州大学
FUZHOU UNIVERSITY

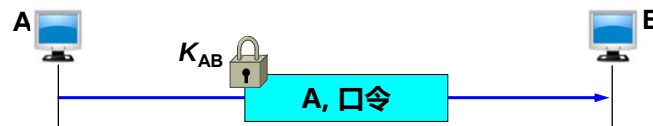
66

7.3 完整性与鉴别

计算机网络

■ 7.3.2 实体鉴别

- 最简单的实体鉴别过程
- 使用共享的**对称密钥** K_{AB} 实现实体鉴别。



存在明显漏洞：不能抵抗重放攻击。

重放攻击 (replay attack)：入侵者 C 不需要破译报文，而是直接把由 A 加密的报文发送给 B，使 B 误认为 C 就是 A。B 就会向伪装成 A 的 C 发送许多本来应当发给 A 的报文。



福州大学
FUZHOU UNIVERSITY

67

7.3 完整性与鉴别

计算机网络

■ 明显的漏洞

- 入侵者 C 可以从网络上截获 A 发给 B 的报文。C 并不需要破译这个报文（因为这可能很花很多时间）而可以直接把这个由 A 加密的报文发送给 B，使 B 误认为 C 就是 A。然后 B 就向伪装是 A 的 C 发送应发给 A 的报文。
- 这就叫做**重放攻击(replay attack)**。C 甚至还可以截获 A 的 IP 地址，然后把 A 的 IP 地址冒充为自己的 IP 地址（这叫做 IP 欺骗），使 B 更加容易受骗。



福州大学
FUZHOU UNIVERSITY

68

7.3 完整性与鉴别

计算机网络

■ 使用不重数

- 为了对付重放攻击，可以使用不重数(nonce)。不重数就是一个不重复使用的大随机数，即“一次一数”。
- 由于不重数不能重复使用，所以 C 在进行重放攻击时无法重复使用所截获的不重数。



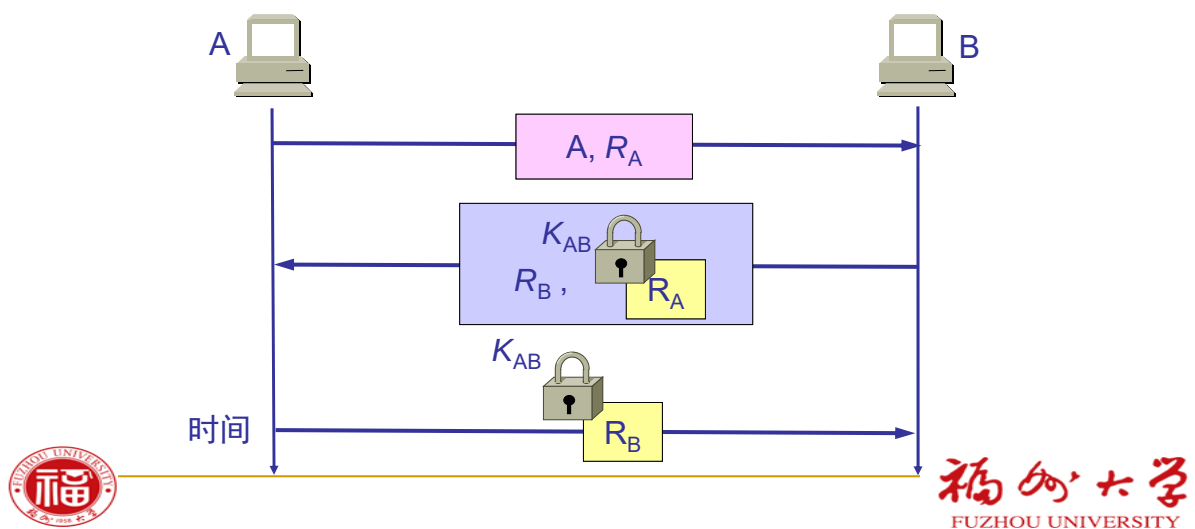
福州大学
FUZHOU UNIVERSITY

69

7.3 完整性与鉴别

计算机网络

■ 使用不重数进行鉴别



福州大学
FUZHOU UNIVERSITY

70

7.3 完整性与鉴别

计算机网络

■ 使用不重数进行鉴别

- 在使用公钥密码体制时，可以对不重数进行签名鉴别。
- **B** 用其私钥对不重数 R_A 进行签名后发回给 **A**。**A** 用 **B** 的公钥核实签名。如能得出自己原来发送的不重数 R_A ，就核实了和自己通信的对方的确是 **B**。
- 同样，**A** 也用自己的私钥对不重数 R_B 进行签名后发送给 **B**。**B** 用 **A** 的公钥核实签名，鉴别了 **A** 的身份。
- 公钥密码体制虽然不必在互相通信的用户之间秘密地分配共享密钥，但仍有受到攻击的可能。



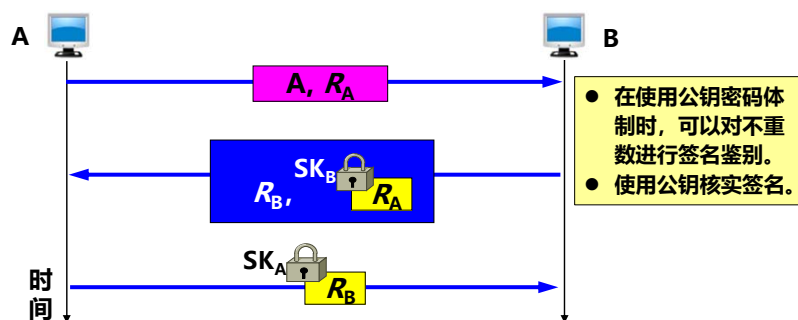
福州大学
FUZHOU UNIVERSITY

71

7.3 完整性与鉴别

计算机网络

■ 使用公钥体制进行不重数鉴别



福州大学
FUZHOU UNIVERSITY

72

7.3 完整性与鉴别

计算机网络

■ 使用不重数进行鉴别

- C 冒充是 A，发送报文给 B，说：“我是 A”。
- B 选择一个不重数 R_B ，发送给 A，但被 C 截获了。
- C 用自己的私钥 SK_C 冒充是 A 的私钥，对 R_B 加密，并发送给 B。
- B 向 A 发送报文，要求对方把解密用的公钥发送过来，但这报文也被 C 截获了。
- C 把自己的公钥 PK_C 冒充是 A 的公钥发送给 B。
- B 用收到的公钥 PK_C 对收到的加密的 R_B 进行解密，其结果当然正确。于是 B 相信通信的对方是 A，接着就向 A 发送许多敏感数据，但都被 C 截获了。

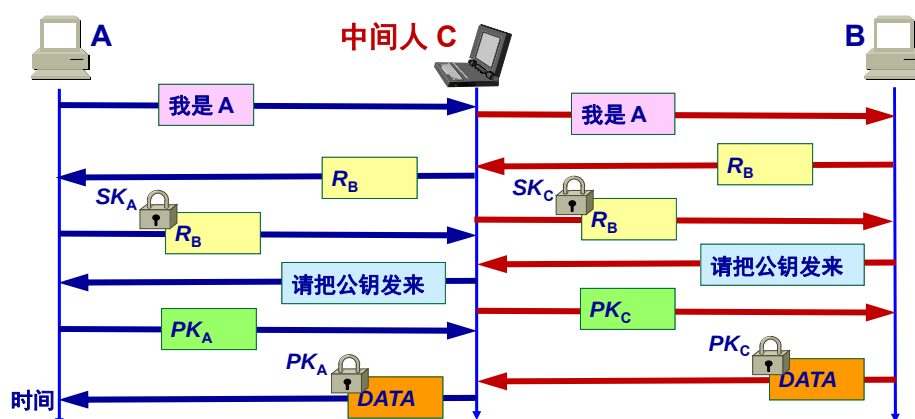


福州大学
FUZHOU UNIVERSITY

73

中间人攻击

计算机网络



由此可见，公钥的分配以及认证公钥的真实性也是一个非常重要的问题。



福州大学
FUZHOU UNIVERSITY

74

7.4 密钥分发和公钥认证

计算机网络

- 由于密码算法是公开的，网络的安全性就完全基于密钥的安全保护上。因此在密码学中出现了一个重要的分支——**密钥管理**。
- **密钥管理包括：**密钥的产生、分配、注入、验证和使用。本节只讨论密钥的分配。
- 密钥分配是密钥管理中最大的问题。密钥必须通过最安全的通路进行分配。



福州大学
FUZHOU UNIVERSITY

75

7.4 密钥分发和公钥认证

计算机网络

- 密钥系统的安全性依赖于密钥的安全保护。在对称密钥密码体制中，通信双方要共享同一个秘密的密钥，如何将密钥分发到通信的双方是一个需要解决的问题。
- 对于公钥密码体制，虽然不需要共享密钥，公钥可以发布在报纸或网站上，但如何验证该公钥确实是某实体真正的公钥仍然是一个问题。
- 这些问题的解决都可以通过使用一个**可信**的中介机构得到解



福州大学
FUZHOU UNIVERSITY

76

7.4 密钥分发和公钥认证

计算机网络

- **网外分配方式**：派非常可靠的信使携带密钥分配给互相通信的各用户。
- **网内分配方式**：密钥自动分配。

但随着用户的增多和网络流量的增大，密钥更换频繁（密钥必须定期更换才能做到可靠），派信使的办法已不再适用，而应采用网内分配方式。



福州大学
FUZHOU UNIVERSITY

77

7.4 密钥分发和公钥认证

计算机网络

■ 7.4.1 对称密钥的分发

- 目前常用的密钥分发方式是设立**密钥分发中心 KDC (Key Distribution Center)**。
- **KDC** 是大家都信任的机构，其任务就是给需要进行秘密通信的用户临时分配一个会话密钥（仅使用一次）。
- 用户 **A** 和 **B** 都是 **KDC** 的登记用户，并已经在 **KDC** 的服务器上安装了各自和 **KDC** 进行通信的**主密钥**（master key） K_A 和 K_B



福州大学
FUZHOU UNIVERSITY

78

7.4 密钥分发和公钥认证

计算机网络

■ 对称密钥的分配说明

- ① 用户 **A** 向密钥分配中心 **KDC** 发送时用明文，说明想和用户 **B** 通信。在明文中给出 **A** 和 **B** 在 **KDC** 登记的身份。
- ② **KDC** 用随机数产生“一次一密”的会话密钥 K_{AB} 供 **A** 和 **B** 的这次会话使用，然后向 **A** 发送回答报文。这个回答报文用 **A** 的密钥 K_A 加密。这个报文中包含有这次会话使用的密钥 K_{AB} 和请 **A** 转给 **B** 的一个**票据(ticket)**，它包含 **A** 和 **B** 在 **KDC** 登记的身份，以及这次会话将要使用的密钥 K_{AB} 。这个票据用 **B** 的密钥 K_B 加密，因此 **A** 无法知道此票据的内容，因为 **A** 没有 **B** 的密钥 K_B 。当然 **A** 也不需要知道此票据的内容。



福州大学
FUZHOU UNIVERSITY

79

7.4 密钥分发和公钥认证

计算机网络

■ 对称密钥的分配说明

- ③ 当 **B** 收到 **A** 转来的票据并使用自己的密钥 K_B 解密后，就知道 **A** 要和他通信，同时也知道 **KDC** 为这次和 **A** 通信所分配的会话密钥 K_{AB} 。
- 此后，**A** 和 **B** 就可使用会话密钥 K_{AB} 进行这次通信了。



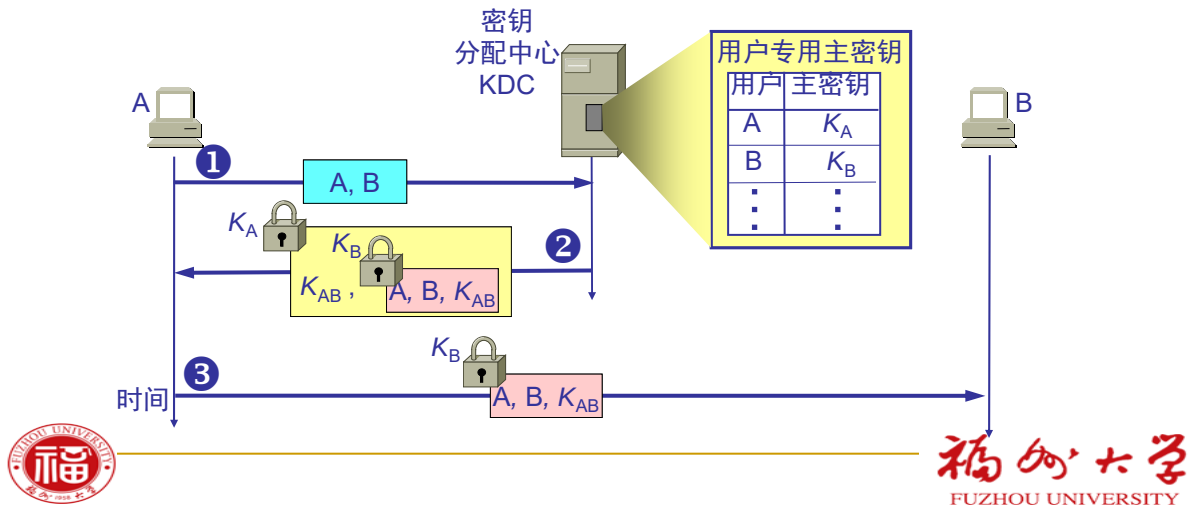
福州大学
FUZHOU UNIVERSITY

80

7.4 密钥分发和公钥认证

计算机网络

■ 对称密钥的分配



81

7.4 密钥分发和公钥认证

计算机网络

■ Kerberos

- ❑ 目前最出名的密钥分配协议是 **Kerberos V5**。
- ❑ **Kerberos** 既是鉴别协议，同时也是 **KDC**，它已经变得很普及，现在是互联网建议标准。
- ❑ **Kerberos** 使用比 **DES** 更加安全的高级加密标准 **AES** 进行加密。
- ❑ **Kerberos** 使用两个服务器：**鉴别服务器AS (Authentication Server)**、**票据授予服务器TGS (Ticket-Granting Server)**。
- ❑ **Kerberos** 只用于客户与服务器之间的鉴别，而不适用于人对人的鉴别。



福州大学
FUZHOU UNIVERSITY

82

Kerberos密钥分配说明

计算机网络

- ① **A** 用明文（包括登记的身份）向鉴别服务器 **AS** 表明自己的身份。
- ② **AS** 向 **A** 发送用 **A** 的对称密钥 K_A 加密的报文，这个报文包含**A**和**TGS**通信的会话密钥 K_S ，以及 **AS** 要发送给 **TGS** 的票据（这个票据是用 **TGS** 的对称密钥 K_{TG} 加密的）。



福州大学
FUZHOU UNIVERSITY

83

Kerberos密钥分配说明

计算机网络

- ③ **A** 向 **TGS** 发送三个项目：
 - 转发鉴别服务器 **AS** 发来的**票据**。
 - 服务器 **B** 的**名字**。这表明 **A** 请求 **B** 的服务。请注意，现在 **A** 向 **TGS** 证明自己的身份并非通过键入口令（因为入侵者能够从网上截获明文口令），而是通过转发 **AS** 发出的票据（只有 **A** 才能提取出）。票据是加密的，入侵者伪造不了。
 - 用 K_S 加密的**时间戳 T**。它用来防止入侵者的重放攻击。



福州大学
FUZHOU UNIVERSITY

84

Kerberos 密钥分配说明

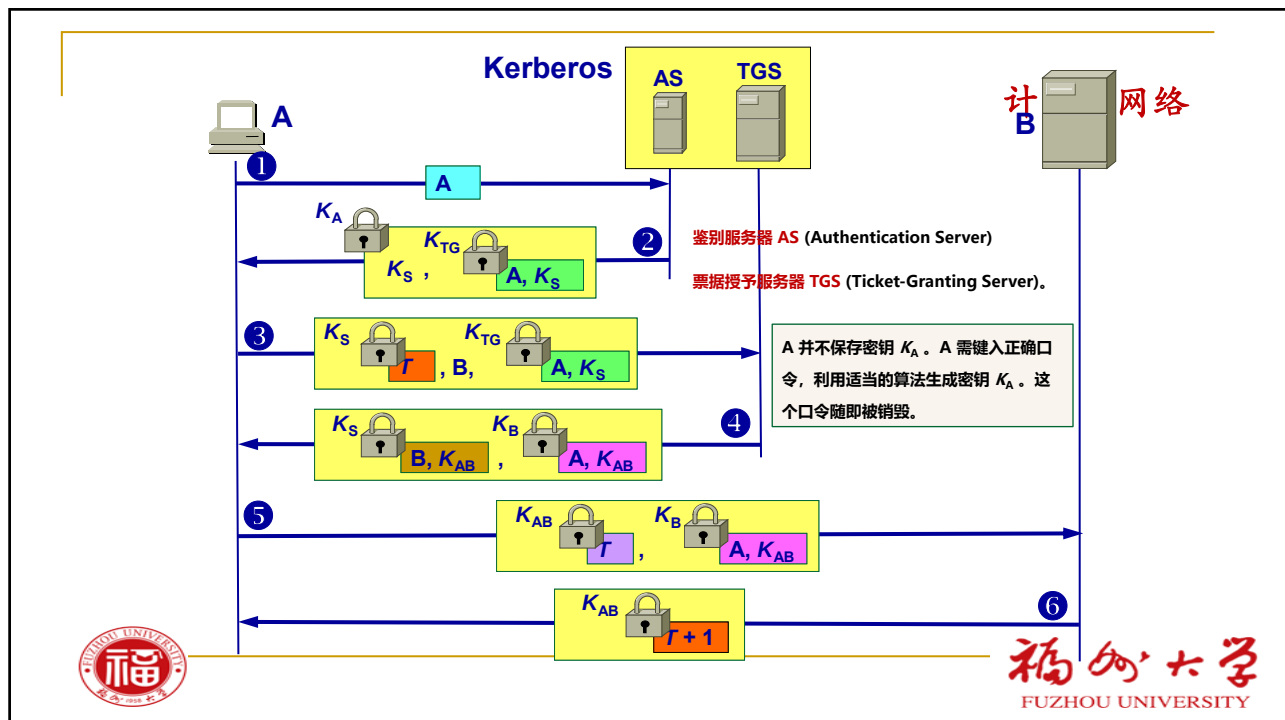
计算机网络

- ④ TGS 发送两个票据，每一个都包含 A 和 B 通信的会话密钥 K_{AB} 。给 A 的票据用 K_S 加密；给 B 的票据用 B 的密钥 K_B 加密。请注意，现在入侵者不能提取 K_{AB} ，因为不知道 K_A 和 K_B 。入侵者也不能重放步骤③，因为入侵者不能把时间戳更换为一个新的（因为不知道 K_S ）。
- ⑤ A 向 B 转发 TGS 发来的票据，同时发送用 K_{AB} 加密的时间戳 T 。
- ⑥ B 把时间戳 T 加 1 来证实收到了票据。B 向 A 发送的报文用密钥 K_{AB} 加密。
- 以后，A 和 B 就使用 TGS 给出的会话密钥 K_{AB} 进行通信。



福州大学
FUZHOU UNIVERSITY

85



86

Kerberos 使用两个服务器

计算机网络

- **Kerberos** 要求所有使用 **Kerberos** 的主机必须在时钟上进行“松散的”同步。
- 所谓“松散的”同步是要求所有主机的时钟误差不能太大，例如，不能超过 **5** 分钟的数量级。
- 这个要求是为了防止重放攻击。



福州大学
FUZHOU UNIVERSITY

87

7.4 密钥分发和公钥认证

计算机网络

■ 7.4.2 公钥的签发与认证

- 在公钥密码体制中，如果每个用户都具有其他用户的公钥，就可实现安全通信。
- 看来好像可以随意公布用户的公钥。其实不然。
- 设想用户 **A** 要欺骗用户 **B**。**A** 可以向 **B** 发送一份伪造是 **C** 发送的报文。**A** 用自己的秘密密钥进行数字签名，并附上 **A** 自己的公钥，谎称这公钥是 **C** 的。**B** 如何知道这个公钥不是 **C** 的呢？



福州大学
FUZHOU UNIVERSITY

88

7.4 密钥分发和公钥认证

计算机网络

■ 7.4.2 公钥的签发与认证

- 需要有一个值得信赖的机构——即**认证中心CA (Certification Authority)**，来将**公钥与其对应的实体（人或机器）进行绑定(binding)**。
- 认证中心一般由政府出资建立。每个实体都有**CA** 发来的**证书(certificate)**，里面有公钥及其拥有者的标识信息。**此证书被 CA 进行了数字签名**。任何用户都可从可信的地方获得认证中心 **CA** 的公钥，**此公钥用来验证某个公钥是否为某个实体所拥有**。有的大公司也提供认证中心服务。



福州大学
FUZHOU UNIVERSITY

89

7.4 密钥分发和公钥认证

计算机网络

■ 公钥的签发与认证

- **数字证书 (digital certificate)**
 - 有时也简称为**证书**。
 - 是对公钥与其对应的实体 (人或机器) 进行绑定的一个证明，因此它常称为**公钥证书**。
 - 每个证书中写有公钥及其拥有者的标识信息（例如：人名、地址、电子邮件地址或 IP 地址等）。
 - **更重要的是**：证书中有 **CA** 使用自己私钥的**数字签名**。
 - 把 **CA** 的数字签名和未签名的 **B** 的证书放在一起，就最后构成了已签名的 **B** 的数字证书。
 - 证书被 **CA** 进行了数字签名，是**不可伪造**的。



福州大学
FUZHOU UNIVERSITY

90

7.4 密钥分发和公钥认证

计算机网络

■ 公钥的签发与认证

□ 数字证书 (digital certificate)

- 任何用户都可从可信任的地方（如代表政府的报纸）获得认证中心 **CA** 的公钥，以验证证书的真伪。
- 数字证书是公开的，不需要加密。



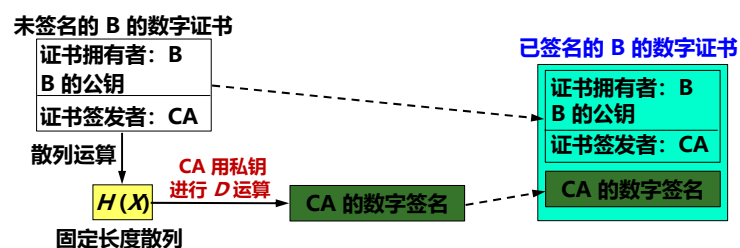
福州大学
FUZHOU UNIVERSITY

91

7.4 密钥分发和公钥认证

计算机网络

■ 已签名的 B 的数字证书的产生过程



- 核实: A 拿到 B 的数字证书后, 使用数字证书上给出的 CA 的公钥, 对数字证书中 CA 的数字签名进行 E 运算, 得出一个数值。再对 B 的数字证书 (CA 数字签名除外的部分) 进行散列运算, 又得出一个数值。比较这两个数值。若一致, 则数字证书是真的。



福州大学
FUZHOU UNIVERSITY

92

7.4 密钥分发和公钥认证

计算机网络

■ X.509 数字证书

- 数字证书的格式必须标准化。
- ITU-T 制定了 **X.509** 协议标准，描述证书的结构。
- IETF 采用 **X.509 V3** 作为互联网的推荐标准。
- **X.509** 又称为互联网公钥基础结构 **PKI (Public Key Infrastructure)**。

版本号	区分 X.509 不同版本
序列号	CA 发放，唯一
签名算法	签署证书所使用的算法和参数
发行者	签发者的唯一标识符
有效期	包括起始时间和终止时间
主体名 (或主题名)	公钥和数字证书拥有者的唯一标识符
公钥	数字证书拥有者的公钥和使用算法的标识符
发行者 ID	任选，唯一，标识发行者
主体 ID	任选，唯一，标识证书所有者
扩展域	扩充信息
认证机构签名	用 CA 私钥对证书签名



福州大学
FUZHOU UNIVERSITY

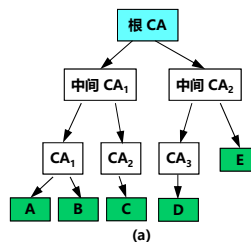
93

7.4 密钥分发和公钥认证

计算机网络

■ 认证系统

- **X.509 提出**：把多级认证中心**链接**起来的，构成一个**树状的认证系统**。
- 末端是用户。
- **最高一级**的认证中心都称为**根认证中心 (Root CA)**，是公认可信的认证中心（或无条件信任的），且其公钥是公开的。



可以有不止一个根 CA。
从根 CA 向下的所有链接都称为信任链。



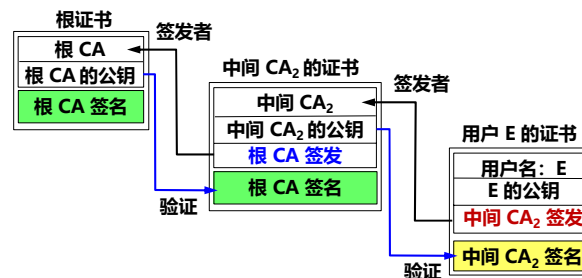
福州大学
FUZHOU UNIVERSITY

94

7.4 密钥分发和公钥认证

计算机网络

■ 证书链



与信任链对应的是证书链。

最顶层的根证书的数字签名是**自签名的**（即自己的私钥给自己签名）。



福州大学
FUZHOU UNIVERSITY

95

7.4 密钥分发和公钥认证

计算机网络

■ 证书撤销与更新

- ❑ 证书不是永久有效，它可以过期，也可以被吊销。
- ❑ 每一个 **CA** 应当有一个公布于众的、用本 **CA** 的私钥签名的**证书撤销名单**，并定期更新。
- ❑ 有很多原因导致证书被吊销，例如：
 1. 用户私钥被盗或遗失。
 2. 用户不再被该 **CA** 认证。
 3. **CA** 签署用户证书的私钥被泄漏。



福州大学
FUZHOU UNIVERSITY

96

7.6 访问控制

计算机网络

■ 7.6.1 访问控制的基本概念

- ❑ 实施访问控制的依据是用户的访问权限。用户访问权限的授予一般遵循**最小特权原则**。
- ❑ 最小特权原则指的是基于用户完成工作的实际需求为用户赋予权限，用户不会被赋予超出其实际需求的权限。
- ❑ 最小特权原则可以有效防范用户滥用权限所带来的安全风险。



福州大学
FUZHOU UNIVERSITY

97

7.6 访问控制

计算机网络

■ 访问控制的基本要素

- ❑ **主体(subject)**指访问活动的发起者。
- ❑ **客体(object)**指访问活动中被访问的对象。
- ❑ **访问**指的是对资源各种类型的使用，例如：读取、修改、创建、删除、执行、发送、接收等操作。
- ❑ **访问策略**体现了系统的授权行为，表现为主体访问客体时需要遵守的约束规则，通常存储在系统的授权服务器中。



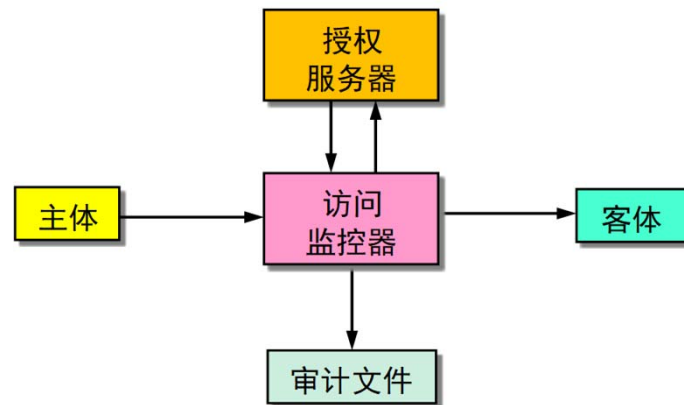
福州大学
FUZHOU UNIVERSITY

98

7.6 访问控制

计算机网络

■ 访问监控器模型



福州大学
FUZHOU UNIVERSITY

99

7.6 访问控制

计算机网络

■ 7.6.2 访问控制策略

- 访问控制策略典型地可分为三类：
 - **自主访问控制DAC** (Discretionary Access Control)
 - **强制访问控制MAC** (Mandatory Access Control)
 - **基于角色的访问控制RBAC** (Role Based Access Control)



福州大学
FUZHOU UNIVERSITY

100

7.6 访问控制

计算机网络

■ 1. 自主访问控制策略

- 自主访问控制通常基于主客体的隶属关系，“自主”指的是客体的拥有者可以自主地决定其他主体对其拥有的客体所进行访问的权限。
- 自主访问控制具有很强的灵活性，但是存在一些明显的缺陷：权限管理过于分散，容易出现漏洞；无法有效控制被攻击主体破坏系统安全性的行为。



福州大学
FUZHOU UNIVERSITY

101

7.6 访问控制

计算机网络

■ 2. 强制访问控制策略

- 强制访问控制与自主访问控制不同，它不允许一般的主体进行访问权限的设置。
- 在强制访问控制中，主体和客体被赋予一定的安全级别，普通用户不能改变自身或任何客体的安全级别，通常只有系统的安全管理员可以进行安全级别的设定。
- 系统通过比较主体和客体的安全级别来决定某个主体是否能够访问某个客体。



福州大学
FUZHOU UNIVERSITY

102

7.6 访问控制

计算机网络

■ 2. 强制访问控制策略

- 下读和上写是在强制访问控制策略中广泛使用的两项原则：
 - **下读原则**：主体的安全级别必须高于或等于被读客体的安全级别，主体读取客体的访问活动才能被允许（向下读）。
 - **上写原则**：主体的安全级别必须低于或等于被写客体的安全级别，主体写客体的访问活动才能被允许（向上写）。



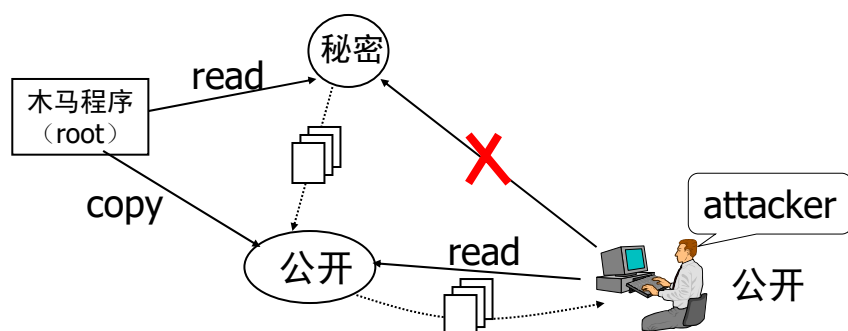
福州大学
FUZHOU UNIVERSITY

103

7.6 访问控制

计算机网络

■ 下读上写原则防止木马窃密攻击



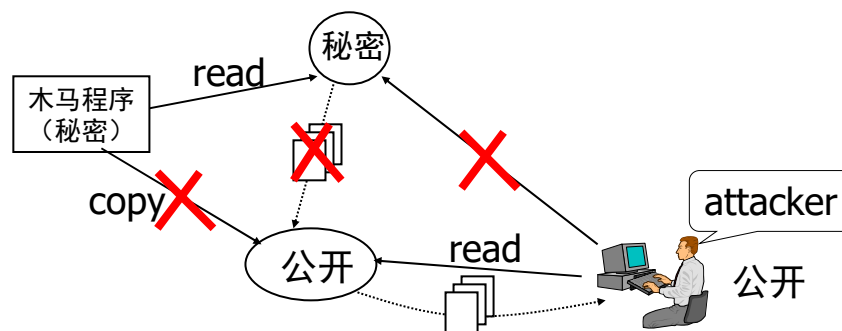
福州大学
FUZHOU UNIVERSITY

104

7.6 访问控制

计算机网络

■ 下读上写原则防止木马窃密攻击



福州大学
FUZHOU UNIVERSITY

105

7.6 访问控制

计算机网络

■ 3. 基于角色的访问控制策略

- 在**RBAC**中，一个用户可以拥有多个角色，一个角色也可以赋予多个用户；
- 一个角色可以拥有多种许可，一种许可也可以分配给多个角色。
- 许可指明了对某客体可以进行的访问类型。



福州大学
FUZHOU UNIVERSITY

106

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

- 物理层：信道加密
- 数据链路层：无线局域网链路层加密、接入控制(802.11i)
- 网络层：主机到主机的数据加密、隧道加密(IPsec)
- 运输层：进程间的鉴别、数据加密(SSL/TLS)
- 应用层：针对具有网络应用的特定的安全机制(例如：安全电子邮件)



福州大学
FUZHOU UNIVERSITY

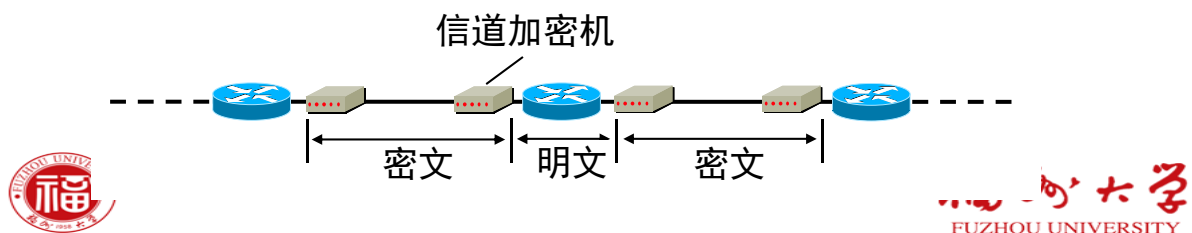
107

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

- 7.7.1 物理层实例：信道加密机
 - 使用信道加密技术的一个好处就是对上层协议几乎没有任何影响（即具有很好的透明性），为通过该链路的所有数据提供安全保护。
 - 不能保证端到端通信的安全性



福州大学
FUZHOU UNIVERSITY

108

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ 7.7.2 数据链路层实例：802.11i

□ 1. 早期无线局域网的安全机制

- **SSID匹配** 该机制提供了一种无加密的鉴别服务，试图接入无线局域网的终端必须配置与BSS中接入点AP相同的SSID。
- **MAC地址过滤** 可以为接入点AP设置允许接入或拒绝接入无线局域网的MAC地址列表。
- **有线等效保密WEP (Wired Equivalent Privacy)** 提供实体鉴别、访问控制、数据加密和完整性检验等。WEP采用对称共享密钥加密技术。

福州大学
FUZHOU UNIVERSITY

109

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ 2. IEEE 802.11i

- 具有更强安全性，主要包括一种可扩展的鉴别机制的集合，更强的加密算法，以及一种密钥分发机制。
- IEEE 802.11i的商业名称为**WPA2**（WiFi Protected Access 2，意思是“无线局域网受保护的接入”的第二个版本）。
- WPA是802.11i的一个子集，在802.11i正式发布前，作为无线局域网安全的过渡标准，代替WEP为802.11无线局域网提供更强的安全性。

福州大学
FUZHOU UNIVERSITY

110

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ 7.6.3 网络层实例：IPsec

- IP几乎不具备任何安全性，不能保证：
 - 数据机密性；
 - 数据完整性；
 - 数据来源认证
- 由于其在设计和实现上存在安全漏洞，使各种攻击有机可乘。例如：攻击者很容易构造一个包含虚假地址的 IP 数据报。



□ IPsec 提供了标准、健壮且包含广泛的机制保证IP 层安全。

福州大学
FUZHOU UNIVERSITY

111

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ 7.6.3 网络层实例：IPsec

- IP 安全性很差，不能保证：
 - 没有为通信提供良好的数据源鉴别机制；
 - 没有为数据提供强大的完整性保护机制；
 - 没有为数据提供任何机密性保护；
 - 在设计和实现上存在安全漏洞，使各种攻击有机可乘。例如：攻击者很容易构造一个包含虚假地址的IP数据报。



福州大学
FUZHOU UNIVERSITY

112

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ 7.7.3 网络层实例：IPsec

- IPsec 就是“IP安全(security)”的缩写。
- IPsec 并不是一个单个的协议，而是能够在 IP 层提供互联网通信安全的协议族。
- IPsec 是个框架，它允许通信双方选择合适的算法和参数（例如，密钥长度）。
- 为保证互操作性，IPsec 还包含了所有 IPsec 的实现都必须有的一套加密算法。



福州大学
FUZHOU UNIVERSITY

113

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ 7.7.3 网络层实例：Ipsec

- 1, IP 安全数据报格式的两个协议
 - 鉴别首部 AH (Authentication Header)协议
 - 提供源点鉴别和数据完整性，但不能保密。
 - 封装安全有效载荷 ESP (Encapsulation Security Payload)协议
 - 提供源点鉴别、数据完整性和保密。
- 2, 有关加密算法的三个协议（在此不讨论）。



3, 互联网密钥交换 IKE (Internet Key Exchange)协议。

福州大学
FUZHOU UNIVERSITY

114

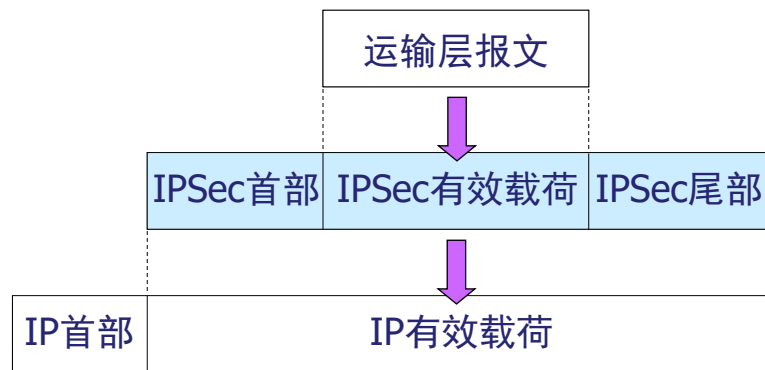
7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ IPsec 的两种运行方式

□ 传输方式



福州大学
FUZHOU UNIVERSITY

115

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ IP 安全数据报有两种工作方式

■ 1, 运输方式 (transport mode):

- 在整个运输层报文段的前后分别添加若干控制信息，再加上 IP 首部，构成 IP 安全数据报。
- 把整个运输层报文段都保护起来，适合于主机到主机之间的安全传送。
- 需要使用 IPsec 的主机都运行 IPsec 协议。



福州大学
FUZHOU UNIVERSITY

116

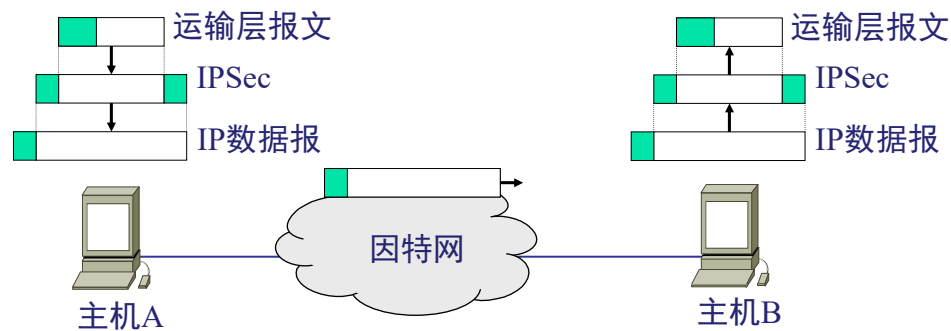
7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ IPsec 的两种运行方式

□ 运输方式



福州大学
FUZHOU UNIVERSITY

117

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ IP 安全数据报有两种工作方式

■ 2, 隧道方式 (tunnel mode):

- 在原始的 IP 数据报的前后分别添加若干控制信息，再加上新的 IP 首部，构成一个 IP 安全数据报。
- 这需要在 IPsec 数据报所经过的所有路由器上都运行 IPsec 协议。
- 隧道方式常用来实现虚拟专用网 VPN。



福州大学
FUZHOU UNIVERSITY

118

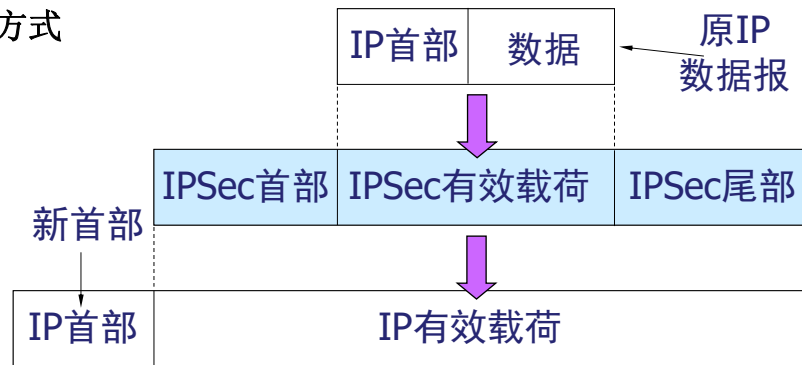
7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ IPsec 的两种运行方式

□ 隧道方式



福州大学
FUZHOU UNIVERSITY

119

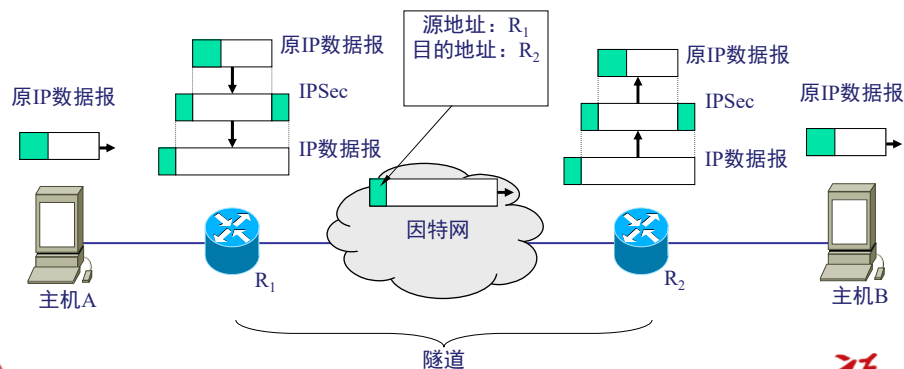
7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ IPsec 的两种运行方式

□ 隧道方式



福州大学
FUZHOU UNIVERSITY

120

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

- IP 安全数据报有两种工作方式
 - 无论使用哪种方式，最后得出的 IP 安全数据报的 IP 首部都是不加密的。
 - 所谓“安全数据报”是指数据报的数据部分是经过加密的，并能够被鉴别的。
 - 通常把数据报的数据部分称为数据报的有效载荷(payload)。

福州大学
FUZHOU UNIVERSITY

121

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

- IPsec 中最主要的两个部分
 - 鉴别首部 AH (Authentication Header): AH 鉴别源点和检查数据完整性，但不能提供机密性服务。
 - 封装安全有效载荷 ESP (Encapsulation Security Payload): ESP 比 AH 复杂得多，它鉴别源点、检查数据完整性和提供机密性服务。

福州大学
FUZHOU UNIVERSITY

122

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ 1. 鉴别首部协议 AH

- 在使用鉴别首部协议 AH 时，把 AH 首部插在原数据报数据部分的前面，同时把 IP 首部中的协议字段置为 51。
- 在传输过程中，中间的路由器都不查看 AH 首部。当数据报到达终点时，目的主机才处理 AH 字段，以鉴别源点和检查数据报的完整性。



协议 = 51



福州大学
FUZHOU UNIVERSITY

123

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ AH 首部

- (1) 下一个首部。标志紧接着本首部的下一个首部的类型（如 TCP 或 UDP）。
- (2) 安全参数索引 SPI。标志安全关联。
- (3) 序号。AH 协议用该序号防止重放攻击。
- (4) 鉴别数据(可变)。一个可变长字段，包含一个经过加密或签名的报文摘要。



福州大学
FUZHOU UNIVERSITY

124

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ 2. 封装安全载荷 ESP

- 使用 **ESP** 时，IP 数据报首部的协议字段置为 **50**。当 IP 首部检查到协议字段是 **50** 时，就知道在 IP 首部后面紧接着的是 **ESP** 首部，同时原 IP 数据报后面增加了两个字段，即 **ESP** 尾部和 **ESP** 数据。
- 在 **ESP** 首部中有标识一个安全关联的安全参数索引 **SPI** (32 位)，和序号 (32 位)。

福州大学
FUZHOU UNIVERSITY

125

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ 2. 封装安全载荷 ESP

- 在 **ESP** 尾部中有下一个首部。**ESP** 尾部和原来数据报的数据部分一起进行加密，因此攻击者无法得知所使用的运输层协议。
- **ESP** 鉴别和 **AH** 中的鉴别数据是一样的。因此，用 **ESP** 封装的数据报既有鉴别源站和检查数据报完整性的功能，又能提供保密。

福州大学
FUZHOU UNIVERSITY

126

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ 安全关联 SA

- 在使用 **AH** 或 **ESP** 之前，先要从源主机到目的主机建立一条网络层的逻辑连接。此逻辑连接叫做**安全关联 SA (Security Association)**。
- **IPsec** 就把传统互联网无连接的网络层转换为具有逻辑连接的网络层。
- 通过安全关联，双方确定将采用的加密或鉴别算法以及各种安全参数，并在**SA**建立时产生一个**32位**的安全参数索引(**Security Parameter Index, SPI**)。

福州大学
FUZHOU UNIVERSITY

127

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ 安全关联的特点

- 安全关联是从源点到终点的**单向连接**，它能够提供安全服务。
- 在安全关联 **SA** 上传送的就是 **IP** 安全数据报。
- 如要进行双向安全通信，则两个方向都需要建立安全关联。

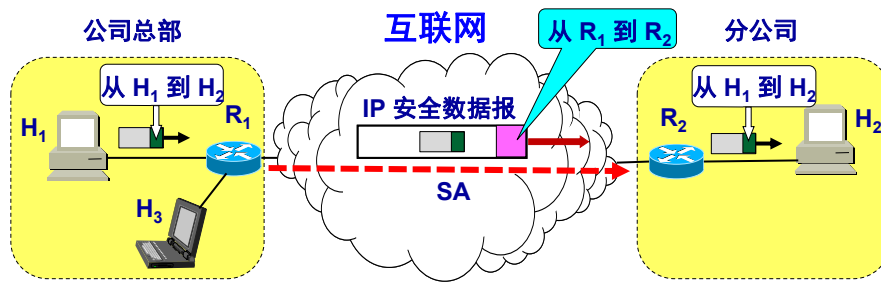
福州大学
FUZHOU UNIVERSITY

128

路由器 R_1 到 R_2 的安全关联 SA

计算机网络

假定公司总部的主机 H_1 要和分公司的主机 H_2 通过互联网进行安全通信。公司总部与分公司之间的安全关联 SA 就是在路由器 R_1 和 R_2 之间建立的。



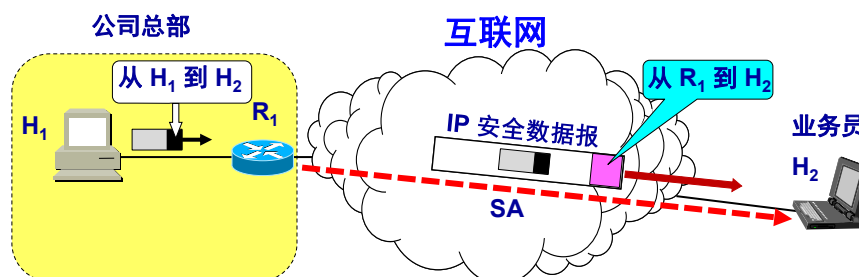
福州大学
FUZHOU UNIVERSITY

129

路由器 R_1 到主机 H_2 的安全关联 SA

计算机网络

若公司总部的主机 H_1 要和某外地业务员的主机 H_2 进行安全通信，需要在公司总部的路由器 R_1 和外地业务员的主机 H_2 建立安全关联 SA。



福州大学
FUZHOU UNIVERSITY

130

安全关联 SA 状态信息

计算机网络

- (1) 一个 32 位的连接标识符，称为安全参数索引 SPI (Security Parameter Index)。
- (2) 安全关联 SA 的源点和终点的 IP 地址（例如路由器 R_1 和 R_2 的 IP 地址）。
- (3) 所使用的加密类型（例如，DES 或 AES）。
- (4) 加密的密钥。
- (5) 完整性检查的类型（例如，使用报文摘要 MD5 或 SHA-1 的报文鉴别码 MAC）。
- (6) 鉴别使用的密钥。



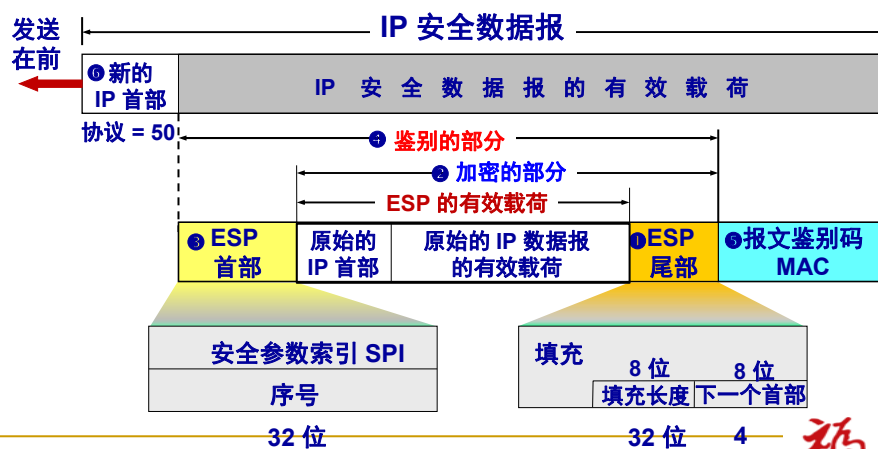
福州大学
FUZHOU UNIVERSITY

131

2. IP 安全数据报的格式

计算机网络

隧道方式下的 IP 安全数据报的格式



福州大学
FUZHOU UNIVERSITY

132

3. IPsec 的其他构件

计算机网络

- **安全关联数据库 SAD (Security Association Database)**
 - 存放SA。
- **安全策略数据库 SPD (Security Policy Database)**
 - 指明什么样的数据报需要进行 IPsec 处理。
- **互联网密钥交换 IKE (Internet Key Exchange)**
 - 为IP安全数据报创建安全关联SA。



福州大学
FUZHOU UNIVERSITY

133

互联网密钥交换 IKE

计算机网络

- **IKE 是个非常复杂的协议，在2014年10月已成为互联网的正式标准 [RFC 7296]。**
- **以另外三个协议为基础：**
 - (1) **Oakley**——是密钥生成协议[RFC 2412]。
 - (2) **安全密钥交换机制 SKEME (Secure Key Exchange Mechanism)** ——是用于密钥交换的协议。它利用公钥加密来实现密钥交换协议中的实体鉴别。
 - (3) **互联网安全关联和密钥管理协议 ISAKMP (Internet Secure Association and Key Management Mechanism)** ——用于实现IKE中定义的密钥交换，使IKE的交换能够以标准化、格式化的报文创建安全关联 SA。



福州大学
FUZHOU UNIVERSITY

134

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ 7.7.4 运输层实例：SSL/TLS

- 网上购物需要的安全服务：
 - (1) 顾客需要确保服务器属于真正的销售商，而不是属于一个冒充者。
 - (2) 顾客与销售商需要确保报文的内容在传输过程中没有被更改。
 - (3) 顾客与销售商需要确保诸如信用卡号之类的敏感信息不被冒充者窃听。



福州大学
FUZHOU UNIVERSITY

135

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ 7.7.4 运输层实例：SSL/TLS

- 运输层安全协议可以提供以上安全服务。
- 现在广泛使用的有两个协议：
 - **SSL** (Secure Socket Layer), 译为**安全套接字层**。
 - **TLS** (Transport Layer Security), 译为**运输层安全**。
- **SSL**是Netscape公司在1994开发的，广泛应用于基于万维网的各种网络应用。
- **TLS**是1995年IETF在SSL 基础上设计的。



福州大学
FUZHOU UNIVERSITY

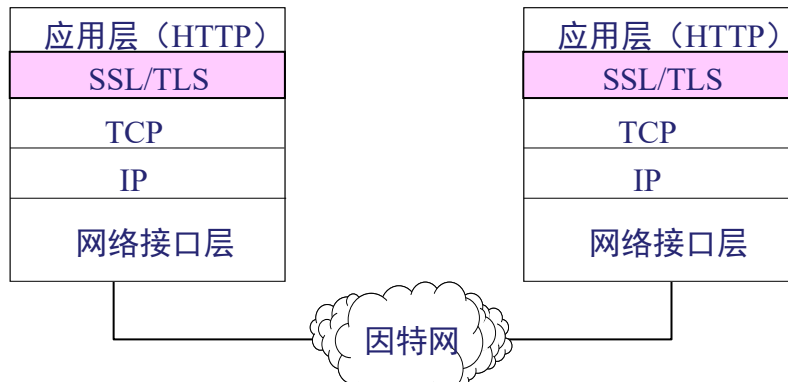
136

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ SSL/TLS 的位置



在发送方，SSL 接收应用层的数据，对数据进行加密，然后把加了密的数据送往 TCP 套接字。在接收方，SSL 从 TCP 套接字读取数据，解密后把数据交给应用层。



福州大学
FUZHOU UNIVERSITY

137

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ SSL 提供以下三种安全服务

- (1) **SSL 服务器鉴别** 允许用户证实服务器的身份。具有 SSL 功能的浏览器维持一个表，上面有一些可信赖的**认证中心 CA (Certificate Authority)**和它们的公钥。
- (2) **加密的 SSL 会话** 客户和服务器交互的所有数据都在发送方加密，在接收方解密。
- (3) **SSL 客户鉴别** 允许服务器证实客户的身份。

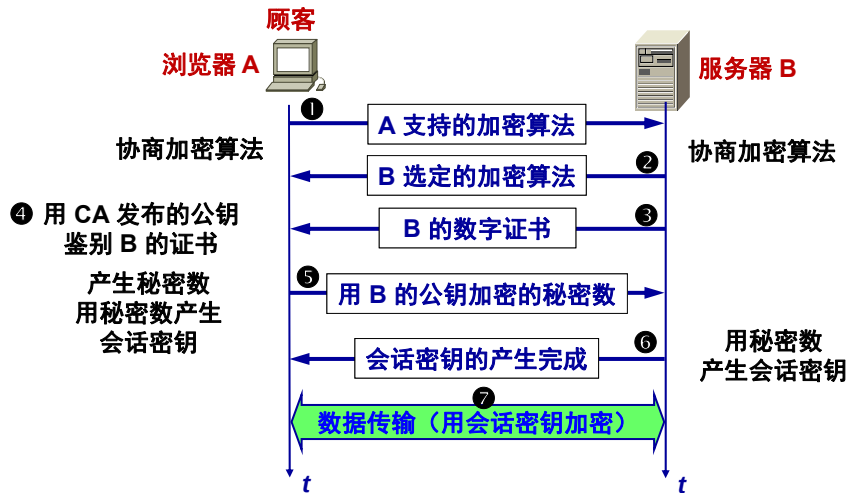


福州大学
FUZHOU UNIVERSITY

138

SSL 安全会话建立过程

计算机网络



福州大学
FUZHOU UNIVERSITY

139

SSL 安全会话建立过程

计算机网络

- **(1) 协商加密算法。** ① 浏览器 A 向服务器 B 发送浏览器的 SSL 版本号和一些可选的加密算法。② B 从中选定自己所支持的算法（如RSA），并告知 A。
- **(2) 服务器鉴别。** ③ 服务器 B 向浏览器 A 发送包含其 RSA 公钥的数字证书。④ A 使用该证书的认证机构 CA 的公开发布的RSA公钥对该证书进行验证。
- **(3) 会话密钥计算。** 由浏览器 A 随机产生一个秘密数。⑤ 用服务器 B 的 RSA 公钥进行加密后发送给 B。⑥ 双方根据协商的算法产生共享的对称会话密钥。
- **(4) 安全数据传输。** ⑦ 双方用会话密钥加密和解密它们之间传送的数据并验证其完整性。



福州大学
FUZHOU UNIVERSITY

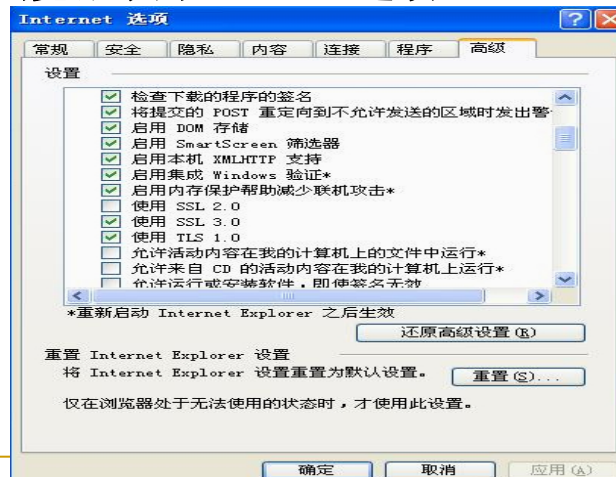
140

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ 浏览器中的SSL/TLS选项



福州大学
FUZHOU UNIVERSITY

141

7.7 网络各层的安全实例

网络各层都需要安全机制

计算机网络

■ 7.7.5 应用层实例： PGP (Pretty Good Privacy)

- PGP 是由Phil Zimmermann于1995开发的一个安全电子邮件软件。
- 虽然 PGP 已被广泛使用，但 PGP 并不是因特网的正式标准。
- PGP通过报文摘要和数字签名技术为电子邮件提供完整性和不可否认，使用对称密钥和公钥的组合加密来提供机密性。



福州大学
FUZHOU UNIVERSITY

142

PGP (Pretty Good Privacy)

计算机网络

- **PGP (Pretty Good Privacy)** 是一个完整的电子邮件安全软件包，包括加密、鉴别、电子签名和压缩等技术。
- **PGP** 并没有使用什么新的概念，它只是将现有的一些算法如 **MD5**, **RSA**, 以及 **IDEA** 等综合在一起而已。
- 虽然 **PGP** 已被广泛使用，但 **PGP** 并不是互联网的正式标准。



福州大学
FUZHOU UNIVERSITY

143

PGP 工作原理

计算机网络

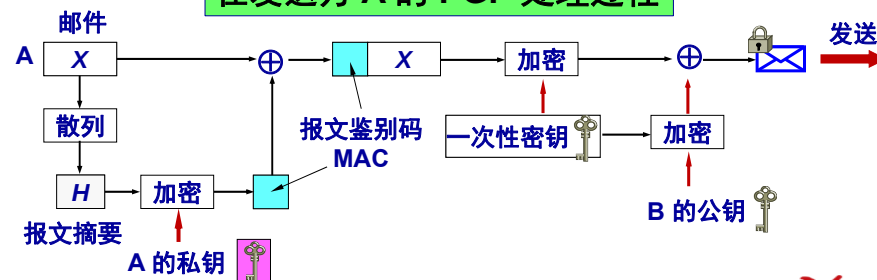
PGP 提供电子邮件的安全性、发送方鉴别和报文完整性。

假定 A 向 B 发送电子邮件明文 X，使用 PGP 进行加密。

A 有三个密钥： A 的私钥、B 的公钥和 A 生成的一次性密钥。

B 有两个密钥： B 的私钥和 A 的公钥。

在发送方 A 的 PGP 处理过程



福州大学
FUZHOU UNIVERSITY

144

发送方 A 的工作

计算机网络

- (1) 对明文邮件 X 进行 MD5 运算，得出 MD5 报文摘要 H 。用 A 的私钥对 H 进行加密（即数字签名），得出报文鉴别码 MAC，把它拼接在明文 X 后面，得到扩展的邮件 (X, MAC) 。
- (2) 使用 A 自己生成的一次性密钥对扩展的邮件 (X, MAC) 进行加密。
- (3) 用 B 的公钥对 A 生成的一次性密钥进行加密。
- (4) 把加了密的一次性密钥和加了密的扩展的邮件发送给 B。



福州大学
FUZHOU UNIVERSITY

145

PGP 工作原理

计算机网络

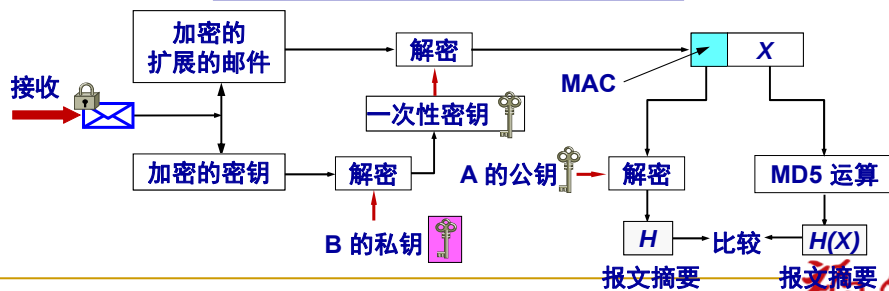
PGP 提供电子邮件的安全性、发送方鉴别和报文完整性。

假定 A 向 B 发送电子邮件明文 X ，使用 PGP 进行加密。

A 有三个密钥： A 的私钥、B 的公钥和 A 生成的一次性密钥。

B 有两个密钥： B 的私钥和 A 的公钥。

在接收方 B 的 PGP 处理过程



福州大学
FUZHOU UNIVERSITY

146

接收方 B 的工作

计算机网络

- (1) 把被加密的一次性密钥和被加密的扩展报文 (X , MAC) 分离开。
- (2) 用 B 自己的私钥解出 A 的一次性密钥。
- (3) 用解出的一次性密钥对报文进行解密，然后分离出明文 X 和 MAC 。
- (4) 用 A 的公钥对 MAC 进行解密（即签名核实），得出报文摘要 H 。这个报文摘要就是 A 原先用明文邮件 X 通过 MD5 运算生成的那个报文摘要。
- (5) 对分离出的明文邮件 X 进行 MD5 报文摘要运算，得出另一个报文摘要 $H(X)$ 。把 $H(X)$ 和前面得出的 H 进行比较，是否和一样。如一样，则对邮件的发送方的鉴别就通过了，报文的完整性也得到肯定。



福州大学
FUZHOU UNIVERSITY

147

7.7 系统安全： 防火墙与入侵检测

计算机网络

- 恶意用户或软件通过网络对计算机系统的攻击已成为当今计算机安全最严重的威胁之一。
- **防火墙(firewall)**作为一种访问控制技术，通过严格控制进出网络边界的分组，禁止任何不必要的通信，从而减少潜在入侵的发生，尽可能降低这类安全威胁所带来的安全风险。
- **入侵检测系统(Intrusion Detection System)**通过对进入网络的分组进行深度分析与检测发现疑是入侵行为的网络活动，并进行报警以便进一步采取相应措施。



福州大学
FUZHOU UNIVERSITY

148

7.8 系统安全： 防火墙与入侵检测

计算机网络

■ 7.8.1 防火墙(firewall)

- **防火墙(firewall)**是把一个组织的内部网络与其他网络（通常就是因特网）隔离开的软件和硬件的组合。根据访问控制策略，它允许一些分组通过，而禁止另一些分组通过。访问控制策略由使用防火墙的组织根据自己的安全需要自行制订。
- 防火墙内的网络称为“**可信网络**” (trusted network)，而将外部的因特网称为“**不可信网络**” (untrusted network)。



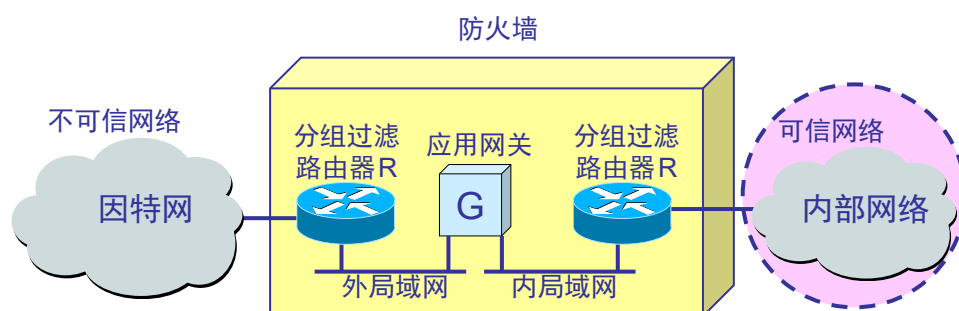
福州大学
FUZHOU UNIVERSITY

149

7.8 系统安全： 防火墙与入侵检测

计算机网络

■ 防火墙在互连网络中的位置



福州大学
FUZHOU UNIVERSITY

150

7.8 系统安全： 防火墙与入侵检测

计算机网络

■ 防火墙技术一般分为两类

- (1) **分组过滤路由器**——是一种具有分组过滤功能的路由器，它根据过滤规则对进出内部网络的分组执行转发或者丢弃（即过滤）。过滤规则基于分组的网络层或运输层首部的信息，例如：源/目的IP地址、源/目的端口、协议类型、标志位等等。
- (2) **应用网关**——在应用层通信中扮演报文中继的角色。一种网络应用需要一个应用网关。在应用网关中可以实现基于应用层数据的过滤和高层用户鉴别。



福州大学
FUZHOU UNIVERSITY

151

7.8 系统安全： 防火墙与入侵检测

计算机网络

■ 7.8.2 入侵检测系统

- 防火墙试图在入侵行为发生之前阻止所有可疑的通信。但事实是不可能阻止所有的入侵行为，有必要采取措施在入侵已经开始，但还没有造成危害或在造成更大危害前，及时检测到入侵，以便尽快阻止入侵，把危害降低到最小。这就需要**入侵检测**系统。



福州大学
FUZHOU UNIVERSITY

152

7.8 系统安全： 防火墙与入侵检测

计算机网络

- **入侵检测系统(Intrusion Detection System, IDS)** 对进入网络的分组执行深度分组检查，当观察到可疑分组时，向网络管理员发出告警或执行阻断操作（由于IDS的“误报”率通常较高，多数情况不执行自动阻断）。
- **IDS**能用于检测多种网络攻击，包括网络映射、端口扫描、DoS攻击、蠕虫和病毒、系统漏洞攻击等。



福州大学
FUZHOU UNIVERSITY

153

7.8 系统安全： 防火墙与入侵检测

计算机网络

- **两种入侵检测方法**
 - 基于特征的入侵检测
 - 基于异常的入侵检测



福州大学
FUZHOU UNIVERSITY

154

7.8 系统安全： 防火墙与入侵检测

计算机网络

■ 基于特征的入侵检测

- ❑ 基于特征的IDS维护一个所有已知攻击标志性特征的数据库。
- ❑ 每个特征是一个与某种入侵活动相关联的规则集，这些规则可能基于单个分组的首部字段值或数据中特定比特串，或者与一系列分组有关。
- ❑ 当发现有与某种攻击特征匹配的分组或分组序列时，则认为可能检测到某种入侵行为。
- ❑ 这些特征和规则通常由网络安全专家生成，机构的网络管理员定制并将其加入到数据库中。



福州大学
FUZHOU UNIVERSITY

155

7.8 系统安全： 防火墙与入侵检测

计算机网络

■ 基于异常的入侵检测

- ❑ 基于特征的IDS只能检测已知攻击。基于异常的IDS可检测未知攻击。
- ❑ 基于异常的IDS通过观察正常运行的网络流量，学习正常流量的统计特性和规律，当检测到网络中流量某种统计规律不符合正常情况时，则认为可能发生了入侵行为。
- ❑ 但区分正常流和统计异常流是一个非常困难的事情。至今为止，大多数部署的IDS主要是基于特征的，尽管某些IDS包括了某些基于异常的特性。



福州大学
FUZHOU UNIVERSITY

156

7.9 网络攻击与防范

计算机网络

■ 7.9.1 网络扫描

- 网络扫描技术是获取攻击目标信息的一种重要技术，能够为攻击者提供大量攻击所需的信息。
- 这些信息包括目标主机的IP地址、工作状态、操作系统类型、运行的程序以及存在的漏洞等等。
- 主机发现、端口扫描、操作系统检测和漏洞扫描是网络扫描的四种主要类型。



福州大学
FUZHOU UNIVERSITY

157

7.9 网络攻击与防范

计算机网络

■ 网络扫描的防范

- 关闭闲置及危险端口，只打开确实需要的端口。
- 使用NAT屏蔽内网主机地址，限制外网主机主动与内网主机进行通信。
- 设置防火墙，严格控制进出分组，过滤不必要的ICMP报文。
- 使用入侵检测系统及时发现网络扫描行为和攻击者IP地址，配置防火墙对该地址的分组进行阻断。



福州大学
FUZHOU UNIVERSITY

158

7.9 网络攻击与防范

计算机网络

■ 7.9.2 网络监听

- 网络监听是攻击者直接获取信息的有效手段。如果数据在网络中明文传输（绝大部分情况都是这样），攻击者可以从截获的分组中分析出账号、口令等敏感信息。
- 攻击者主要采用局域网分组嗅探、交换机毒化攻击、**ARP**欺骗等攻击手段。



福州大学
FUZHOU UNIVERSITY

159

7.9 网络攻击与防范

计算机网络

■ 网络监听的防范

- 尽量使用交换机，划分更细的**VLAN**
- 为某些交换机端口设置允许学习的源**MAC**地址数量的上限
- 将**IP**地址、**MAC**地址与交换机的端口进行静态绑定
- 对于要重点保护的主机或路由器使用静态**ARP**表
- 进行数据加密和实体鉴别技术，避免使用**Telnet**这些不安全的软件



福州大学
FUZHOU UNIVERSITY

160

7.9 网络攻击与防范

计算机网络

■ 7.9.3 拒绝服务攻击

- 拒绝服务**DoS (Denial of Service)**攻击是攻击者最常使用的一种行之有效且难以防范的攻击手段
- 是针对系统可用性的攻击，主要通过消耗网络带宽或系统资源导致网络或系统不胜负荷，以至于瘫痪而停止提供正常的网络服务或使服务质量显著降低
- 主要以网站、路由器、域名服务器等网络基础设施为攻击目标，危害极大



福州大学
FUZHOU UNIVERSITY

161

7.9 网络攻击与防范

计算机网络

■ 分布式拒绝服务攻击

- 如果处于不同位置的多个攻击者同时向一个或多个目标发起拒绝服务攻击，或者一个或多个攻击者控制了位于不同位置的多台主机，并利用这些主机对目标同时实施拒绝服务攻击，则称这种攻击为分布式拒绝服务**DDoS (Distributed Denial of Service)**攻击，它是拒绝服务攻击最主要的一种形式。



福州大学
FUZHOU UNIVERSITY

162

7.9 网络攻击与防范

- 以下措施可以部分地解决问题。

- 利用网络防火墙对恶意分组进行过滤
- 在入口路由器进行源端控制
- 对路由器流经的IP数据报首部进行自动标记，以追溯攻击源，然后隔离攻击源或采取相应的法律手段
- 通过分析分组首部特征和流量特征检测正在发生的DoS攻击，并进行预警

到目前为止，还没有一种完全有效地抵抗DoS攻击的技术和方法，特别是基于大规模流量攻击的DDoS更难防范。



福州大学
FUZHOU UNIVERSITY